AEROVANT TECHNOLOGIES

THREATREADY

ThreatReady Firewall
Learning notebook

ThreatReady Firewall by Aerovant Technologies: hands-on firewall administration training from first cable to incident containment.

30	5	~10 h	October 2026
tasks	levels	hands-on	edition

Companion to the simulator. Every lab, host, address and attack in it is simulated; ThreatWall is a fictional appliance used for training.

Contents

How to use this notebook

The lab network

How a packet crosses the firewall

Networking essentials

Level 0 — Access

0.1 Cable the PC and get an address
0.2 Open the management page
0.3 Run the Setup Guide
0.4 Learn the GUI layout
0.5 Register and license
0.6 Back up before changes
0.7 Admin session basics

Level 1 — Fresher

1.1 Interfaces and zones
1.2 Default route and DNS
1.3 DHCP server and reservations
1.4 MAC-IP anti-spoof
1.5 Address objects and groups
1.6 First access rule and outbound NAT

Level 2 — Junior engineer

2.1 Service objects and schedules
2.2 Publish a web server
2.3 Rule order, shadowing and cleanup
2.4 VLANs and segmentation
2.5 Content filtering
2.6 Application control
2.7 Local users and authentication

Level 3 — Advanced

3.1 IPS and gateway anti-virus
3.2 DPI-SSL (TLS inspection)
3.3 SSL VPN for remote users
3.4 Site-to-site IPsec VPN
3.5 Dual WAN with SD-WAN failover

Level 4 — Expert

4.1 High availability
4.2 Packet-flow troubleshooting
4.3 IPsec troubleshooting
4.4 Hardening and audit
4.5 Capstone: contain a compromised host

Glossary

How to use this notebook

The task panel in the simulator tells you *what* to do, one action at a time. This notebook tells you *why*: what each feature really is, what happens inside the firewall when you click OK, and how the same work looks on a real job. Read a lesson before you start the task, keep it open while you work, or come back to it when something does not make sense.

Every lesson follows the same pattern:

- **The situation** and **why it matters**: the business problem the task solves.
- **What it actually is**: the concept in plain words, with a flow diagram.
- **What happens under the hood**: the mechanism, step by step.
- **Lab values** and **the steps, and why each one**: the exact settings with the reason behind each action.
- **Common mistakes**, **if it does not work**, **key terms**, **on the job** and **check yourself**.

How the lab works. The screen is the browser on a lab PC called ADMIN-PC. Lab Tools at the bottom hold the PC console, the traffic tester, the list of lab hosts and lab controls (unplug a link, fail an ISP, power off a unit). Steps advance on their own when the saved configuration or a simulated test proves them; nobody types the configuration for you. Tasks unlock in order and a later change can make an earlier task show *Re-verify*, exactly as a real change can break something that used to work.

Guided or Practice. In Guided mode the panel shows values and highlights the next control. In Practice mode they stay hidden until you ask for a hint. A good routine: read the lesson, do the task in Guided mode, then repeat the level in Practice mode with this notebook closed.

All addresses are private ranges or documentation ranges (RFC 5737: 192.0.2.0/24, 198.51.100.0/24, 203.0.113.0/24). Websites use fictional `.example` domains. Passwords, keys and one-time codes are training-only.

The lab network

The fictional company KGI has a head office firewall, `KGI-HQ-FW`, connecting the office LAN, a DMZ for the public web server, two internet links, a branch office over IPsec and remote staff over SSL VPN. By the end of Level 4 you will have built all of it.

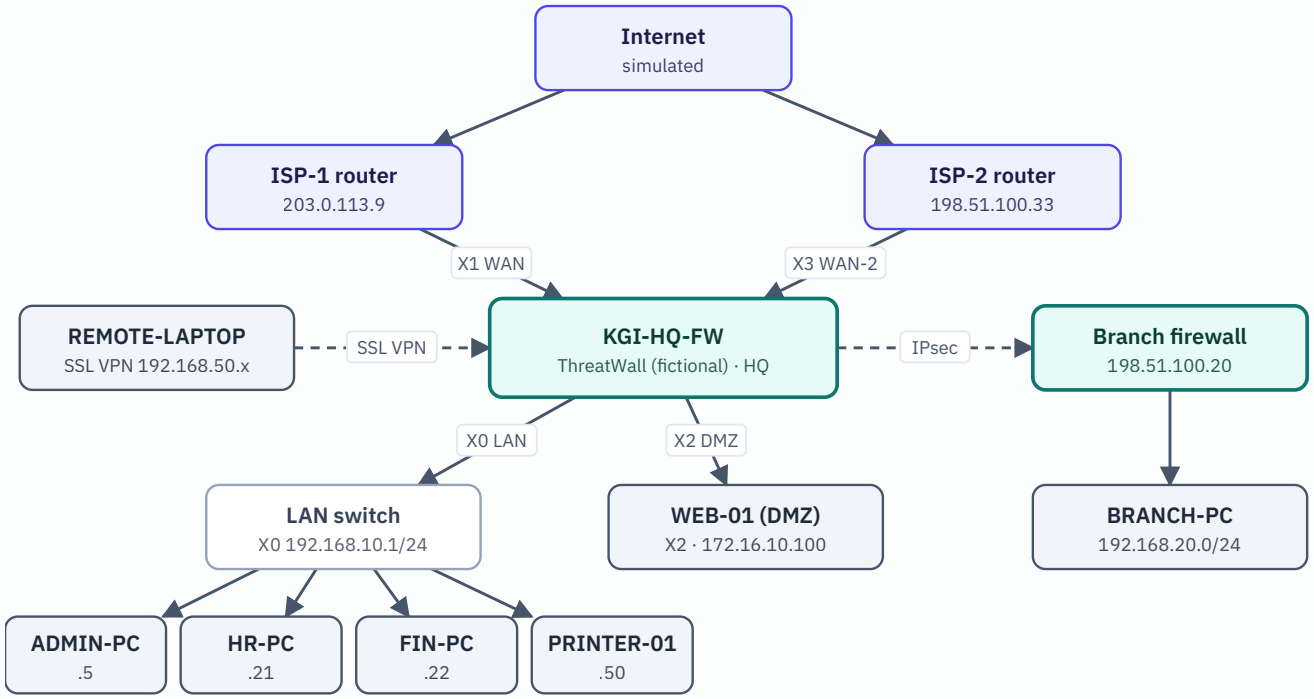


Figure A. The finished lab. Dashed lines are VPN tunnels that run over the internet.

ITEM	ADDRESS	BUILT IN
Factory management (X0)	`192.168.168.168/24`	0.1
Office LAN (X0)	`192.168.10.1/24` · DHCP `192.168.10.100–192.168.10.199`	1.1, 1.3
WAN, ISP-1 (X1)	`203.0.113.10/29` · gateway `203.0.113.9`	1.1
DMZ (X2) · WEB-01	`172.16.10.1/24` · server `172.16.10.100` · public `203.0.113.11`	2.2
VLANs on X0	10 LAN 10.10.10.1/24 · 20 Finance 10.10.20.1/24 · 30 Guest 10.10.30.1/24	2.4
SSL VPN pool	`192.168.50.10–192.168.50.50`	3.3
Branch	peer `198.51.100.20` · LAN `192.168.20.0/24`	3.4

ITEM	ADDRESS	BUILT IN
WAN, ISP-2 (X3)	`198.51.100.34/29` · gateway `198.51.100.33`	3.5
Hosts	ADMIN-PC `192.168.10.5` · HR-PC `192.168.10.21` · FIN-PC `192.168.10.22` · PRINTER-01 `192.168.10.50`	—

How a packet crosses the firewall

Almost every task changes one stage of this path. When something does not work, walk the path in order and ask which stage dropped the packet: the traffic tester and Packet Monitor in the simulator show exactly that.

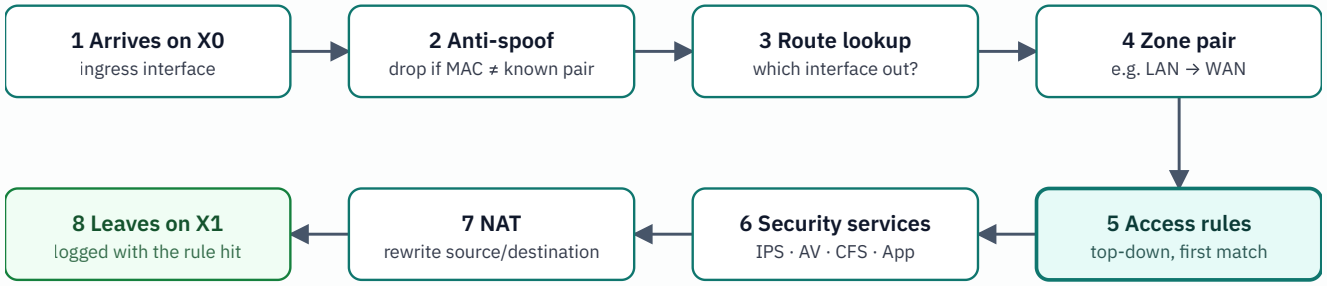


Figure B. The order of checks for a packet from the LAN to the internet. A drop at any stage ends the journey and is logged.

1. **Ingress.** The packet arrives on an interface, which tells the firewall its source zone.
2. **Anti-spoof.** If enforced, the source IP and MAC must match a known pair (task 1.4).
3. **Route lookup.** The most specific route decides the exit interface and therefore the destination zone (1.2, 3.5, 4.2).
4. **Zone pair.** Source and destination zones select which rule list applies, for example LAN → WAN.
5. **Access rules.** Read top-down; the first match allows or denies, and nothing matching means deny (1.6, 2.1, 2.3, 2.7).
6. **Security services.** IPS, anti-virus, content filter and application control inspect allowed traffic (2.5, 2.6, 3.1, 3.2).
7. **NAT.** Addresses are rewritten: private to public on the way out, public to private for published servers (1.6, 2.2).
8. **Egress.** The packet leaves and the connection is logged with the rule it matched.

Networking essentials

ADDRESSES AND SUBNETS

An IPv4 address is four numbers from 0 to 255. The subnet mask (or its short form, the CIDR prefix such as `/24`) says how many leading bits are the network part. Two devices in the same subnet talk directly; anything else goes through a router, here the firewall.

PREFIX	MASK	ADDRESSES	USED IN THIS LAB FOR
/32	`255.255.255.255`	1	one host (address objects)
/29	`255.255.255.248`	8 (6 usable)	the ISP blocks on X1 and X3
/24	`255.255.255.0`	256 (254 usable)	office LAN, DMZ, VLANs
/0	`0.0.0.0`	everything	the default route

PRIVATE, PUBLIC AND DOCUMENTATION ADDRESSES

Private ranges (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`) are used inside organisations and never routed on the internet, which is why NAT exists. Public addresses are unique worldwide. Documentation ranges are reserved for examples like this lab and never belong to a real network.

PORTS AND SERVICES

SERVICE	PORT	WHAT IT IS
DNS	`UDP/TCP 53`	name lookups
HTTP	`TCP 80`	plain web
HTTPS	`TCP 443`	encrypted web, firewall GUI
SSH	`TCP 22`	remote command line
RDP	`TCP 3389`	Windows remote desktop
SMB	`TCP 445`	Windows file sharing
IKE / IPsec	`UDP 500, 4500`	site-to-site VPN
SSL VPN	`TCP 4433 (lab)`	remote access
Syslog	`UDP 514`	central logging

ZONES AND TRUST

A zone groups interfaces with the same level of trust. Typical zones are LAN (trusted, your staff), WAN (untrusted, the internet), DMZ (servers others can reach) and special zones for VPN users. Rules are

written between zones, so a new port added to an existing zone immediately follows that zone's rules.

STATEFUL INSPECTION

The firewall remembers every connection it allowed. Replies to an allowed connection are let back in automatically; you write rules for who may *start* a connection, not for the replies.

LEVEL 0

Access

From the box to the first login

Level 0 takes you from a boxed appliance to a safe first login. Nothing here is advanced, but every later task depends on it: a PC that can reach the firewall, a management page you trust, a password that is not the factory one, a licence, a backup, and an admin session that closes itself.

0.1 Cable the PC and get an address · ~5 min

0.2 Open the management page · ~5 min

0.3 Run the Setup Guide · ~10 min

0.4 Learn the GUI layout · ~10 min

0.5 Register and license · ~5 min

0.6 Back up before changes · ~5 min

0.7 Admin session basics · ~5 min

LEVEL 0 — ACCESS · FRESHER · ABOUT 5 MINUTES

0.1 Cable the PC and get an address

A new firewall manages itself on X0 at 192.168.168.168 and hands out addresses 192.168.168.100–.199 to anything plugged in there.

THE SITUATION

Plug ADMIN-PC into X0, let it get a DHCP address, then prove the PC can reach the firewall with ping.

WHY IT MATTERS

Every later step happens through this cable. If the PC is not in the firewall's subnet, the management page simply never loads.

WHAT IT ACTUALLY IS

Before you can configure anything, your computer must be able to talk to the firewall. Computers talk to each other with IP addresses, and two machines on the same cable can only talk directly if their addresses are in the same subnet: the same street, if an address is a house number.

A new firewall manages itself on port X0 at `192.168.168.168` and runs a DHCP server there. DHCP is the service that hands out addresses automatically, so you do not have to type one into the PC.

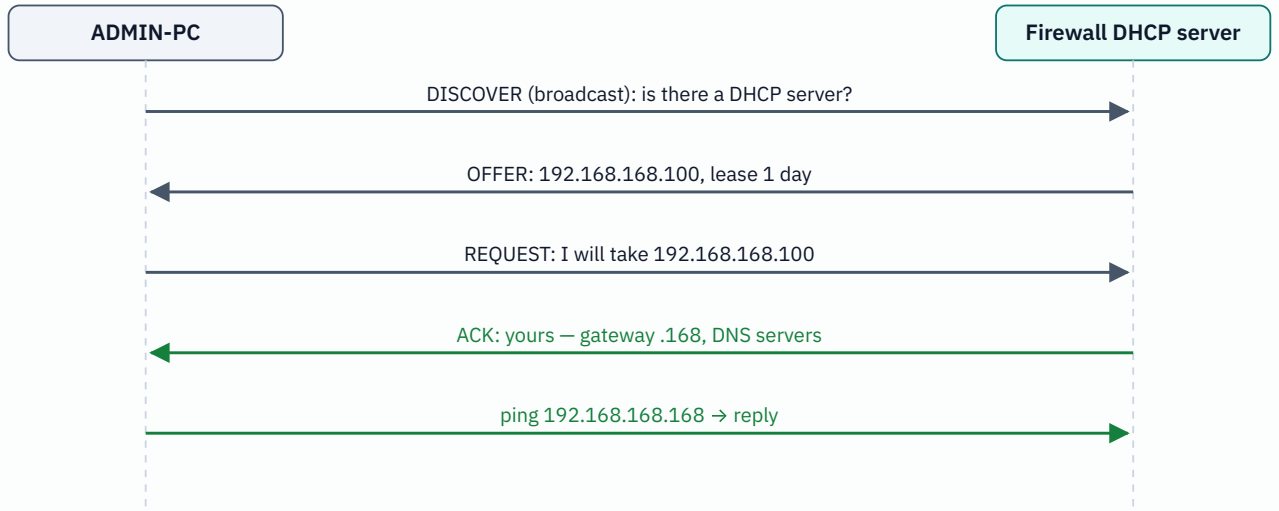


Figure 0.1. The PC gets its address in four messages, then proves the path with ping.

WHAT HAPPENS UNDER THE HOOD

When you plug in the cable, the PC shouts on the wire: "is there a DHCP server?" (DISCOVER). The firewall offers a free address from its pool `192.168.168.100–.199` (OFFER). The PC asks to keep it (REQUEST) and the firewall confirms, adding the gateway and DNS servers (ACK). `ipconfig` shows the result.

`ping` sends a small ICMP "echo request" and waits for an "echo reply". A reply proves three things at once: the cable works, both sides are in the same subnet, and the firewall is alive. "General failure" means the PC has no usable address yet; "Request timed out" means the address is fine but nothing answers.

LAB VALUES

Firewall X0	`192.168.168.168/24`
PC address	`192.168.168.100–.199 (DHCP)`

THE STEPS, AND WHY EACH ONE

1. **Open Lab Tools › PC Console**

   Lab Tools is the “physical world” around the firewall: your PC, cables and test traffic. It sits at the bottom of the screen.

2. **Plug the PC’s cable into the firewall’s X0 port**

   X0 is the LAN port. On a factory unit it is the only port that answers management traffic.

3. **Run ipconfig to see the address the PC received** · `ipconfig`

   The firewall’s DHCP server answers the PC’s request with an address, mask, gateway and DNS server. ipconfig shows what it got.

4. **Ping the firewall** · `ping 192.168.168.168`

   A reply proves layer 1 (cable), layer 2 (ARP) and layer 3 (same subnet) all work before you open a browser.

How it is verified: Re-checked from the live lab: cable, PC address and a ping evaluated by the engine.

COMMON MISTAKES

- Pinging before the PC has an address (you get “General failure”).
- Typing 192.168.1.1 or another vendor’s default address.

IF IT DOES NOT WORK

- ipconfig shows 169.254.x.x: DHCP did not answer — check the cable and run ipconfig /renew.
- Ping times out: confirm the PC and X0 are in the same /24.

KEY TERMS

IP address

The number that identifies a device on a network, e.g. 192.168.168.100.

Subnet

The group of addresses that can talk directly. /24 means the first three numbers must match.

DHCP

Automatic address assignment: discover, offer, request, acknowledge.

ping (ICMP)

A reachability test: one echo request, one echo reply.

> **ON THE JOB**
>
> On a real site the first hour is exactly this: a laptop, a cable and a console. If `ipconfig` shows an address starting with 169.254, DHCP failed and the PC gave itself a useless "link-local" address. Check the cable and the port before anything else.

CHECK YOURSELF

1. **ipconfig shows 169.254.10.3. What happened?**
   Answer: No DHCP server answered, so Windows picked a link-local address. Check the cable is in X0 and the link is up.
2. **Why must the PC be in 192.168.168.x?**
   Answer: The firewall is 192.168.168.168/24; only addresses in that subnet can reach it without a router.

LEVEL 0 — ACCESS · FRESHER · ABOUT 5 MINUTES

0.2 Open the management page

The firewall's web GUI listens on HTTPS. A new unit uses a self-signed certificate, so the browser warns you once.

THE SITUATION

Browse to https://192.168.168.168, check the warning is for the address you expect, and proceed to the login page.

WHY IT MATTERS

You must know the difference between an expected self-signed warning on a box you just cabled and a real interception warning.

WHAT IT ACTUALLY IS

The management page is a website served by the firewall over HTTPS. HTTPS encrypts the connection and uses a certificate to prove the site is who it claims to be. Browsers trust certificates signed by a short list of certificate authorities (CAs).

A brand-new appliance has no CA-signed certificate. It signs its own ("self-signed"), so the browser cannot verify it and shows a warning. On a box you have just cabled to your own PC, that warning is expected. On a site you use every day, the same warning could mean someone is intercepting your traffic.

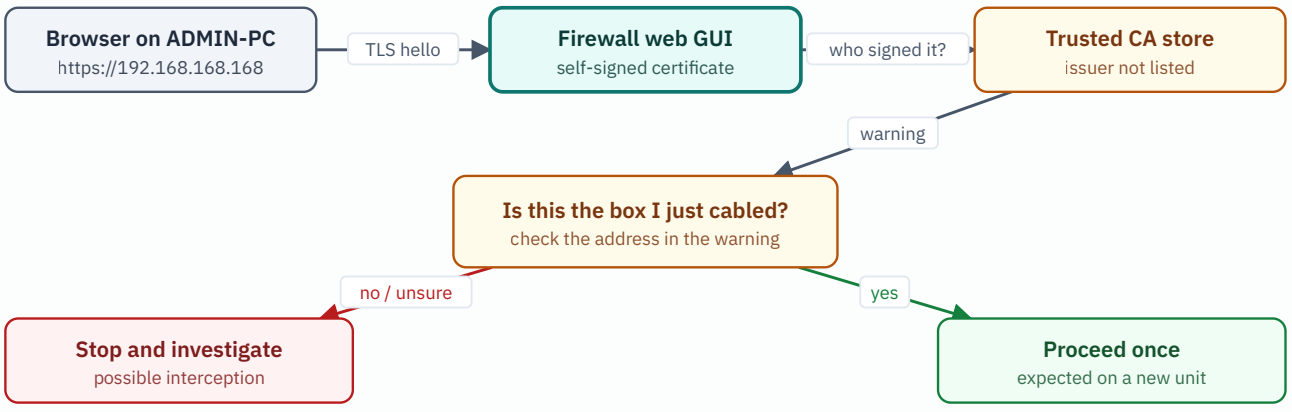


Figure 0.2. The warning is about who signed the certificate, not about the firewall being broken.

WHAT HAPPENS UNDER THE HOOD

Your browser connects to `https://192.168.168.168`. The firewall presents its certificate. The browser looks up who signed it, finds no trusted CA, and stops to ask you. The encryption still works; what is missing is proof of identity.

Before clicking Proceed, read the address in the warning. It must be the one you typed, on a cable you control. In task 4.4 you replace this certificate with one from an internal CA that the PCs already trust, and the warning disappears for good.

LAB VALUES

URL	`https://192.168.168.168`

THE STEPS, AND WHY EACH ONE

1. **Type the management address in the browser and press Enter** · `https://192.168.168.168`

   The address bar at the top of the screen is the browser on ADMIN-PC. Type the full URL including https://.

2. **Read the warning, then click Advanced**

   NET::ERR_CERT_AUTHORITY_INVALID means the certificate was not issued by an authority your PC trusts. A factory firewall signs its own.

3. **Check the address is 192.168.168.168, then click “Proceed (unsafe)”**

   Only accept this warning for an appliance you control and just cabled. Task 4.4 replaces the certificate.

How it is verified: The engine re-checks that ADMIN-PC reaches the firewall’s HTTPS management on the address in use.

COMMON MISTAKES

- Using http:// — the appliance does not serve management over HTTP.
- Clicking “Back to safety” and assuming the firewall is broken.

IF IT DOES NOT WORK

- “This site can’t be reached”: go back to task 0.1 — the PC address or cable is wrong.
- “Refused to connect”: HTTPS management is off on that interface.

KEY TERMS

HTTPS / TLS

Encrypted web traffic. TLS is the protocol underneath.

Certificate

A signed statement: "this key belongs to this name".

Certificate authority (CA)

An issuer that browsers trust to sign certificates.

Self-signed

A certificate signed by its own key. Encrypted, but unverified.

ON THE JOB

Teaching people to click through every certificate warning is how interception attacks succeed. Accept a self-signed warning only on equipment you physically control, and fix it properly (internal CA) as soon as the device is in service.

CHECK YOURSELF

1. **Is a self-signed connection encrypted?**
   Answer: Yes. The warning is about identity, not encryption.
2. **Why not use http:// to avoid the warning?**
   Answer: The appliance does not serve management over plain HTTP, and plain HTTP would send your password in clear text.

LEVEL 0 — ACCESS · FRESHER · ABOUT 10 MINUTES

0.3 Run the Setup Guide

The factory login (admin / password) is published in every manual. The Setup Guide forces a new password and sets the basics.

THE SITUATION

Sign in with the factory credentials, replace the password, name the firewall, keep WAN on DHCP for now, apply, and sign in again.

WHY IT MATTERS

A firewall left on its default password belongs to whoever tries it first. Changing it is always step one.

WHAT IT ACTUALLY IS

Every appliance ships with the same factory login, printed in every manual and known to every attacker. The first job on any new device is to replace it.

The Setup Guide is a wizard that forces the essentials in one pass: a strong password, the device name and the time zone. Interfaces are left as they are on purpose: changing X0 now would cut the cable you are using to manage the box.

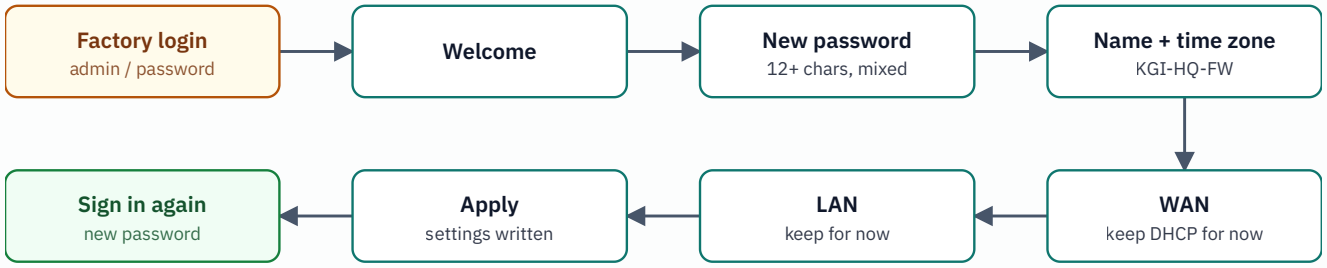


Figure 0.3. The Setup Guide walks the essentials in a fixed order and ends with a fresh sign-in.

WHAT HAPPENS UNDER THE HOOD

You sign in with `admin / password`. The wizard refuses to continue until the new password meets the policy (12+ characters with upper case, lower case, digits and a symbol). The firewall name `KGI-HQ-FW` will appear in logs, alerts and backups, so every record says which box it came from.

The time zone matters more than it looks: log timestamps, schedules (task 2.1) and one-time codes (tasks 3.3 and 4.4) all depend on the clock. When you click Apply the settings are written and your old session ends, so you sign in again with the new password.

LAB VALUES

Factory login	`admin / password`
Firewall name	`KGI-HQ-FW`
Time zone	`Asia/Kolkata`
New password	`12+ chars, upper, lower, digit, symbol`

THE STEPS, AND WHY EACH ONE

1. **Sign in with the factory credentials** · `admin / password`

   The Setup Guide opens automatically because the appliance is still on factory defaults.

2. **Read the Welcome page, then click Next**

3. **Enter and confirm a new administrator password** · `12+ characters with upper, lower, digit, symbol`

   Long and mixed passwords resist guessing. In this lab use a practice password, never a real one.

4. **Click Next**

5. **Set the firewall name** · `KGI-HQ-FW`

   The name appears in logs, alerts and VPN peers so you always know which box you are looking at.

6. **Check the time zone** · `Asia/Kolkata`

   Schedules (task 2.1) and log timestamps use the firewall's time zone.

7. **Click Next through WAN (keep DHCP) and LAN**

   Task 1.1 sets the static WAN address, so DHCP is fine here.

8. **Review the summary and click Apply**

9. **Click Done and sign in with your new password**

How it is verified: Checked against the saved configuration: setup flag, password hash and time zone.

COMMON MISTAKES

- Reusing a real password in a lab.
- Changing X0 here — that is task 1.1 and it drops your session.

IF IT DOES NOT WORK

- Login keeps failing: after five failures the login locks for 30 seconds.
- Forgot the new password: Reset the lab from the user menu (it clears all progress).

KEY TERMS

Default credentials

The factory username and password, public for every unit.

Hostname

The device name used in logs, alerts and backups.

Password policy

Rules a password must meet: length and character types.

> **ON THE JOB**
>
> Automated scanners try default logins on every exposed device within minutes. Changing them is item one on every hardening checklist and every audit. Use a password manager, never a password you use anywhere else.

CHECK YOURSELF

1. **Why keep WAN on DHCP and LAN unchanged in the wizard?**
   Answer: Each is configured properly in task 1.1. Changing X0 here would disconnect the PC you are working from.
2. **What else depends on the time zone?**
   Answer: Log timestamps, rule schedules and one-time passwords.

LEVEL 0 — ACCESS · FRESHER · ABOUT 10 MINUTES

0.4 Learn the GUI layout

The GUI has six views across the top — HOME, MONITOR, DEVICE, NETWORK, OBJECT, POLICY — each with its own left menu.

THE SITUATION

Visit the pages you will use most so you can find them without thinking.

WHY IT MATTERS

In an outage you will not have time to hunt for the logs page.

WHAT IT ACTUALLY IS

A firewall GUI is large. Knowing where things live is a skill in itself, because during an outage you will not have time to hunt for the logs page.

The GUI is split into six views across the top. HOME is the overview, MONITOR is what is happening now (charts, logs, packet capture), DEVICE is the box itself (settings, users, HA), NETWORK is how it connects (interfaces, DHCP, VPN, SD-WAN), OBJECT is the named building blocks, and POLICY is the decisions: access, NAT, routing and security services.

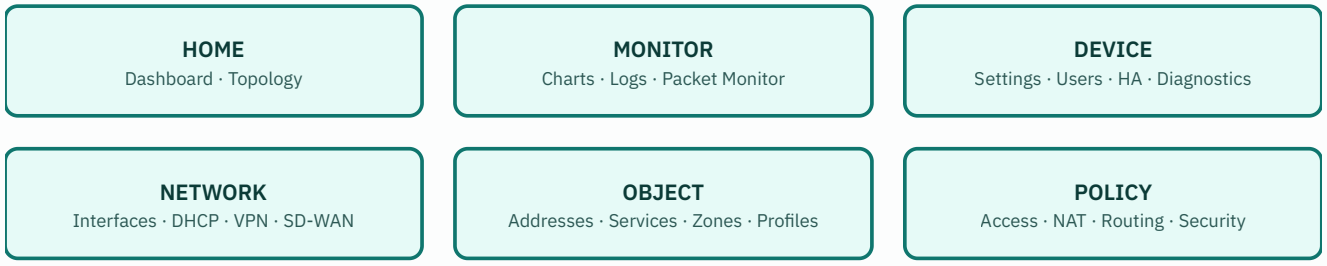


Figure 0.4. Six views, each with its own left menu. Pages save only on Accept or OK.

WHAT HAPPENS UNDER THE HOOD

Every page shows a breadcrumb such as `KGI-HQ-FW › Network › System › Interfaces`. Use it to tell someone exactly where to look. Changes are not live until you click Accept (settings pages) or OK (dialogs). Navigating away discards them.

A common surprise: routes are not under NETWORK. In this classic layout they are under POLICY › Rules and Policies › Routing Rules, because a route is a decision about where traffic goes.

LAB VALUES

Views	`HOME · MONITOR · DEVICE · NETWORK · OBJECT · POLICY`

THE STEPS, AND WHY EACH ONE

1. **Look at HOME › Dashboard: model, serial, firmware, interfaces and alerts**

   The dashboard is where you start every troubleshooting session: is the box up, which ports have link, what changed?

2. **Open HOME › Dashboard › Topology**

   Topology shows which zone and subnet sits behind each port.

3. **Open MONITOR › Real-Time Charts › System Monitor**

   MONITOR is read-only: charts, logs and capture tools.

4. **Open DEVICE › Settings › Administration**

   DEVICE holds the appliance itself: name, admins, licences, firmware.

5. **Open NETWORK › System › Interfaces**

   NETWORK holds addressing: interfaces, DHCP, DNS, VPN.

6. **Open OBJECT › Match Objects › Addresses**

   OBJECT holds the reusable names that rules refer to.

7. **Open POLICY › Rules and Policies › Access Rules**

   POLICY holds what is allowed: access rules, NAT, routing, security services.

8. **Open MONITOR › Logs › System Logs**

   Logs are your evidence for every later task.

9. **Note the breadcrumb (host › view › group › page) and that pages save only when you click Accept or OK**

How it is verified: Each page visit was recorded as you navigated.

COMMON MISTAKES

- Looking for routes under NETWORK — in Classic mode they are under POLICY › Rules and Policies › Routing Rules.

IF IT DOES NOT WORK

- Lost? Use the search icon (top right) and type a page name or a task number.

KEY TERMS

View

One of the six top-level areas.

Breadcrumb

The path to the current page.

Accept / OK

The buttons that actually save a change.

> **ON THE JOB**
>
> On a support call you will often guide someone else through the GUI. Saying "POLICY, Rules and Policies, Access Rules, LAN to WAN" gets them there in seconds.

CHECK YOURSELF

1. **Where are routes?**
   Answer: POLICY › Rules and Policies › Routing Rules.
2. **You change a field and open another page. Is it saved?**
   Answer: No. Only Accept or OK saves.

LEVEL 0 — ACCESS · FRESHER · ABOUT 5 MINUTES

0.5 Register and license

Security services (content filter, IPS, anti-virus, DPI-SSL, SSL VPN, HA) only run once the appliance is registered and licensed.

THE SITUATION

Register the serial number and authentication code from the dashboard, then confirm every service shows Licensed.

WHY IT MATTERS

Unlicensed services look configured but do nothing — a dangerous illusion of protection.

WHAT IT ACTUALLY IS

The basic firewall (routing, rules, NAT) works out of the box. The security services (content filter, intrusion prevention, gateway anti-virus, DPI-SSL, SSL VPN capacity, HA) are subscriptions that only run when the appliance is registered and licensed.

The dangerous part: an unlicensed service still has its settings page and its Enable box. It looks configured while doing nothing. That is a false sense of protection.

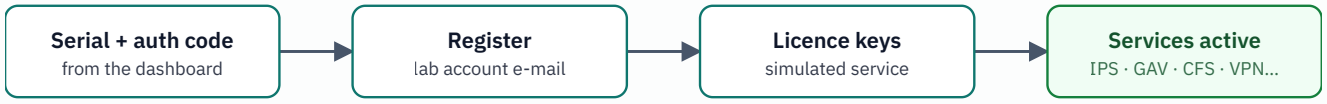


Figure 0.5. Registration turns the serial number into active service licences.

WHAT HAPPENS UNDER THE HOOD

Each unit has a serial number and an authentication code. Registering ties them to an account and downloads the licence keys. In this lab the registration service is simulated and any `.example` address works; you never enter a real vendor account.

After registering, DEVICE › Licenses must show every service as Licensed with an expiry date. Expiry dates matter: when a licence lapses, signatures stop updating and protection quietly ages.

LAB VALUES

Serial / auth code	`as shown on HOME › Dashboard and DEVICE › Licenses`
Account e-mail	`any lab address, e.g. admin@kgi.example`

THE STEPS, AND WHY EACH ONE

1. **Open DEVICE › Settings › Licenses**
2. **Click Register**
3. **Enter a lab account e-mail address** · `admin@kgi.example`

   In the lab no e-mail is sent anywhere. On real kit this is your vendor portal account.
4. **Enter the serial number exactly as shown on this page**
5. **Enter the authentication code**
6. **Click Register**
7. **Confirm every service in the table now shows Licensed with an expiry date**

How it is verified: Checked against the saved licensing table.

COMMON MISTAKES

- Typing the letter O instead of zero in the serial.
- Assuming a service works because its page has an Enable box.

IF IT DOES NOT WORK

- “Must match”: copy the serial and code from the top of the Licenses page.

KEY TERMS

Serial number

Unique hardware identity of the unit.

Authentication code

A second code proving you hold that unit.

Subscription service

A feature that needs an active licence and updates.

> **ON THE JOB**
>
> Licence expiry is a frequent audit finding. Put renewal dates in a calendar and check the licence page after every renewal.

CHECK YOURSELF

1. **IPS is enabled but the licence expired. Are you protected?**
   Answer: No. Without a licence the service does not inspect or update.
2. **Common typing mistake in the serial?**
   Answer: The letter O instead of the digit 0.

0.6 Back up before changes

A local backup is a snapshot stored on the appliance; an export is a file you keep somewhere else.

THE SITUATION

Create a local backup labelled “Before changes”, then export the configuration file.

WHY IT MATTERS

Every change from task 1.1 onwards can lock you out. A backup turns a disaster into a two-minute restore.

WHAT IT ACTUALLY IS

Everything from task 1.1 onwards can lock you out or break the network. A backup taken before you start turns a disaster into a two-minute restore.

There are two kinds. A local backup is a snapshot stored on the appliance itself, quick to roll back to. An export is a file you keep somewhere else. If the hardware fails, the local backup dies with it; the export does not.

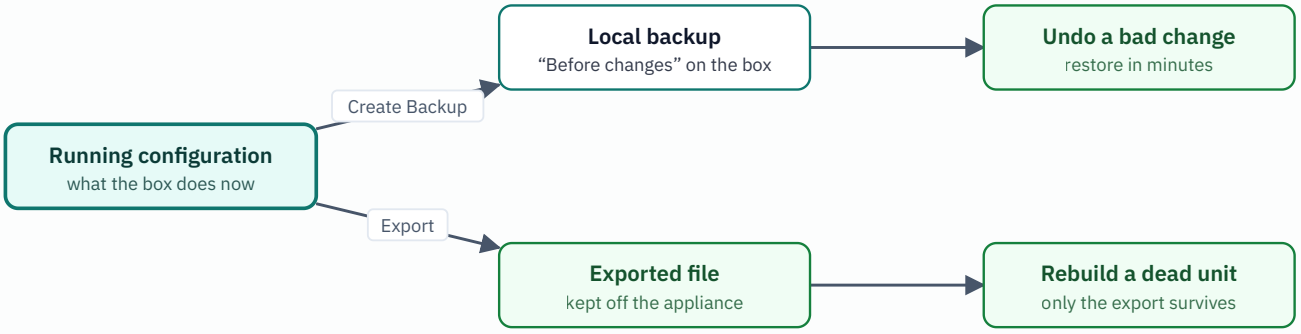


Figure 0.6. A local backup fixes a bad change; only an exported file survives a dead unit.

WHAT HAPPENS UNDER THE HOOD

Create Backup saves the current configuration with a comment. Write why you took it ("Before changes") so that months later someone can pick the right one. Export Configuration downloads a file you store off the box: a share, a password vault, a ticket.

Restoring a backup replaces the running configuration with the saved one. That is why you take one before each change window, not after.

LAB VALUES

Backup comment	`Before changes`

THE STEPS, AND WHY EACH ONE

1. **Open DEVICE › Settings › Firmware and Settings**
2. **Click Create Backup**
3. **Give it a comment that says why** · `Before changes`
4. **Click Create**
5. **Click Export Configuration to keep a copy off the appliance**

   The lab export downloads a JSON file with lab-only values. It contains no real secrets.

How it is verified: Backups are read from the saved configuration; the export from the audit log.

COMMON MISTAKES

- Skipping the comment — six months later nobody knows which backup is good.

IF IT DOES NOT WORK

- Restore needs a reboot on real kit; the lab applies it at once and logs you out of nothing.

KEY TERMS

Running configuration

What the firewall is doing right now.

Local backup

A snapshot kept on the appliance.

Export

A configuration file stored off the appliance.

> **ON THE JOB**
>
> A change ticket in most companies requires "backup taken: yes" before work starts. Name backups with the date and the reason.

CHECK YOURSELF

1. **The firewall will not boot. Which copy helps?**
   Answer: Only the exported file.

2. **Why comment a backup?**

   Answer: So the right restore point can be found later.

LEVEL 0 — ACCESS · FRESHER · ABOUT 5 MINUTES

0.7 Admin session basics

DEVICE › Settings › Administration holds the firewall name and how long an idle admin session stays open.

THE SITUATION

Set the name to KGI-HQ-FW (if not already) and the idle timeout to 10 minutes, then find your change in the audit log.

WHY IT MATTERS

An unattended admin session is an open door. A clear name makes every log and alert unambiguous.

WHAT IT ACTUALLY IS

An admin session left open on an unattended PC is an open door: anyone passing by has full control of the firewall. An idle timeout closes it automatically.

The audit log records every configuration change with time, user and detail. It is how you answer "who changed this, and when?".

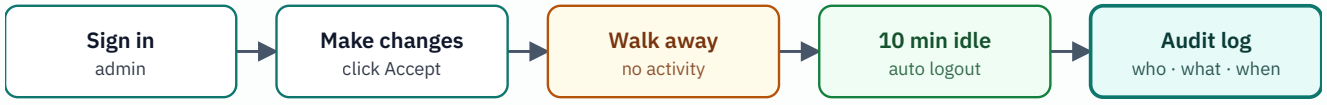


Figure 0.7. Idle sessions close themselves, and every change lands in the audit log.

WHAT HAPPENS UNDER THE HOOD

DEVICE › Settings › Administration holds the firewall name and "Log out the administrator after inactivity of". Ten minutes is a common balance between safety and convenience. Accept saves it, and the change appears at the top of MONITOR › Logs › Auditing Logs.

The timeout counts from your last click or key press. When it expires you return to the login page and nothing unsaved is kept.

LAB VALUES

Firewall name	`KGI-HQ-FW`
Log out after inactivity	`10 minutes`

THE STEPS, AND WHY EACH ONE

1 **Open DEVICE › Settings › Administration**

2. **Set Firewall Name** · `KGI-HQ-FW`
3. **Set “Log out the administrator after inactivity of” to 10 minutes** · `10`
4. **Click Accept**
5. **Open MONITOR › Logs › Auditing Logs**
   Every saved change is recorded with who, when and what. This is your change log.
6. **Find your Administration change at the top of the audit log**

How it is verified: Checked against the saved Administration settings.

COMMON MISTAKES

- Editing the field and navigating away without clicking Accept.

IF IT DOES NOT WORK

- Accept is greyed out: nothing changed compared with the saved values.

KEY TERMS

Idle timeout

Automatic logout after a period without activity.

Audit log

A record of configuration changes: who, what, when.

> **ON THE JOB**
>
> Auditors ask for both: a session timeout and an audit trail they can sample. Get used to checking the audit log after each change; it is also your proof that the change was made.

CHECK YOURSELF

1. **Where do you prove a setting was changed?**
   Answer: MONITOR › Logs › Auditing Logs.
2. **Why ten minutes and not two hours?**
   Answer: The shorter the idle window, the smaller the chance someone else uses your session.

LEVEL 1

Fresher

A safe, working office LAN

Level 1 builds a working, safe office network: the internet link, the office subnet, addresses handed out automatically, protection against address theft, named objects, and the first rule that lets staff browse while everything else stays closed.

1.1 Interfaces and zones · ~15 min

1.2 Default route and DNS · ~10 min

1.3 DHCP server and reservations · ~10 min

1.4 MAC-IP anti-spoof · ~15 min

1.5 Address objects and groups · ~15 min

1.6 First access rule and outbound NAT · ~20 min

LEVEL 1 — FRESHER · FRESHER · ABOUT 15 MINUTES

1.1 Interfaces and zones

Each port belongs to a zone (LAN, WAN, DMZ…) and has an address. Zones decide which rules apply; the address decides which subnet the port serves.

THE SITUATION

Give X1 the ISP's static address with Ping-only management, then move X0 to the office subnet 192.168.10.1/24 and reconnect to it.

WHY IT MATTERS

A WAN that answers HTTPS or SSH invites attacks from the whole internet. The office plan uses 192.168.10.0/24, not the factory subnet.

WHAT IT ACTUALLY IS

Each physical port (X0, X1, X2…) has an address and belongs to a zone. The address decides which subnet the port serves. The zone is a security label (LAN, WAN, DMZ) and decides which rules apply to traffic entering or leaving that port.

The ISP gave the office a small public block, `203.0.113.8/29`: eight addresses, of which `.9` is their router and `.10` is ours. The office itself uses the private network `192.168.10.0/24`, so X0 moves from the factory address to `192.168.10.1`.

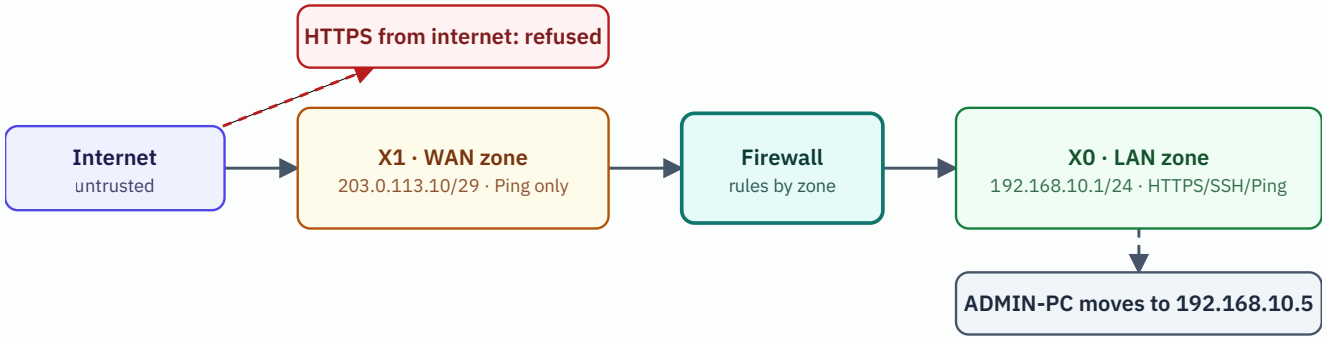


Figure 1.1. WAN answers only ping; the office lives on X0 in 192.168.10.0/24.

WHAT HAPPENS UNDER THE HOOD

A subnet mask says which part of an address is the network. `255.255.255.248` (/29) leaves 3 bits for hosts: 8 addresses. `255.255.255.0` (/24) leaves 8 bits: 256. Typing /24 on the WAN would make the firewall think half the internet is "local" and stop routing to it.

Management settings decide which services the firewall answers on each port. X1 faces the internet, so it answers ping only: HTTPS or SSH there would invite password attacks from everywhere. When you re-

address X0 your session drops, because the PC is still in the old subnet. You give ADMIN-PC `192.168.10.5`, browse to `https://192.168.10.1`, and you are back.

LAB VALUES

X1 (WAN)	`203.0.113.10 / 255.255.255.248`
X1 gateway	`203.0.113.9`
X1 DNS	`1.1.1.1, 8.8.8.8`
X1 management	`Ping only`
X0 (LAN)	`192.168.10.1 / 255.255.255.0`
X0 management	`HTTPS, Ping, SSH`

THE STEPS, AND WHY EACH ONE

1. **Open NETWORK › System › Interfaces**

   The table lists every port: its zone, address, link and which management protocols it answers.

2. **Click Configure (pencil) on X1**

3. **Set X1 to Static with the ISP's address** · `IP Assignment: static · IP Address: 203.0.113.10 · Subnet Mask: 255.255.255.248 · Default Gateway: 203.0.113.9`

   /29 (255.255.255.248) gives 6 usable addresses: .9 is the ISP router, .10 is ours, .11 is spare for a published server (task 2.2).

4. **Enter the DNS servers** · `DNS Server 1: 1.1.1.1 · DNS Server 2: 8.8.8.8`

5. **Under Management, leave only Ping ticked on X1** · `Ping: true · HTTPS: false · SSH: false · HTTP: false · SNMP: false`

   Ping helps your ISP and you test reachability. Admin protocols on the WAN are the most attacked surface of any firewall.

6. **Click OK to save X1**

7. **Click Configure on X0 — the port your PC is plugged into**

   You are about to change the address you are managing the firewall through. Expect to be disconnected.

8. **Change X0 to the office subnet** · `IP Address: 192.168.10.1 · Subnet Mask: 255.255.255.0 · HTTPS: true · Ping: true · SSH: true`

9. **Click OK, read the warning, then "Save and disconnect"**

10 **Give ADMIN-PC an address in the new subnet (Lab Tools › PC Console › static)** · `192.168.10.5 / 255.255.255.0, gateway 192.168.10.1, DNS 1.1.1.1`

> Your PC and the firewall must share a subnet to talk. The DHCP scope is fixed in task 1.3, so use a static address for now.

11 **Type the new management address in the browser** · `https://192.168.10.1`

12 **Accept the certificate warning again and sign in**

How it is verified: Saved interface values are compared with the plan, and the engine proves HTTPS works from the LAN and is refused from the internet.

COMMON MISTAKES

- Typing 255.255.255.0 for the WAN mask — the ISP gave a /29.
- Leaving HTTPS ticked on X1 “just for now”.
- Changing X0 and then not knowing why the GUI stopped answering.

IF IT DOES NOT WORK

- Lost the GUI after saving X0: set ADMIN-PC to 192.168.10.5/24 gateway 192.168.10.1 and browse to https://192.168.10.1.
- Completely locked out: the disconnected screen offers serial-console recovery.

KEY TERMS

Interface

A port on the firewall (X0, X1…), physical or virtual.

Zone

A trust label on interfaces. Rules are written between zones.

Subnet mask / CIDR

255.255.255.248 = /29 = 8 addresses.

Management access

Which admin services (HTTPS, SSH, ping) a port answers.

> **ON THE JOB**
>
> Never leave HTTPS or SSH management open on the WAN "just for now". Exposed management pages are among the most exploited entry points on firewalls. Manage from inside, or through the VPN.

CHECK YOURSELF

1. **Why did the GUI stop answering after you changed X0?**

   Answer: The PC was still in 192.168.168.x and could no longer reach the new address.

2. **How many addresses does /29 contain?**

   Answer: Eight: network, six usable hosts, broadcast.

LEVEL 1 — FRESHER · FRESHER · ABOUT 10 MINUTES

1.2 Default route and DNS

The default route sends everything not local to the ISP router. DNS turns names into addresses for the firewall and, through its proxy, for clients.

THE SITUATION

Confirm the default route via X1, make sure the firewall uses 1.1.1.1 and 8.8.8.8, then prove it from DEVICE › Diagnostics.

WHY IT MATTERS

When “the internet is down”, the first questions are always: is there a route, does the gateway answer, does DNS resolve?

WHAT IT ACTUALLY IS

A route tells the firewall where to send traffic for a destination. The default route, `0.0.0.0/0`, means "everything I have no better route for" and points to the ISP router. Without it the firewall knows only its own subnets.

DNS turns names such as `www.search.example` into addresses. People and applications use names; packets need addresses. If DNS fails, "the internet is down" even though routing is fine.

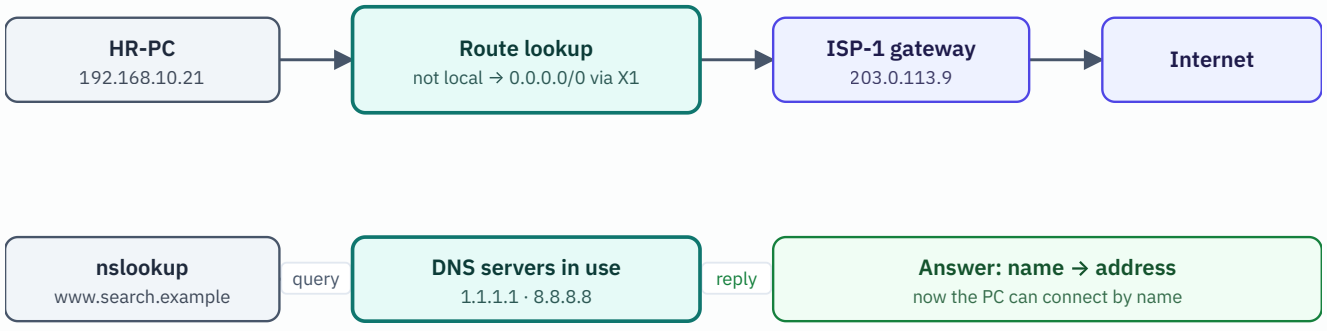


Figure 1.2. Anything not local follows the default route; names are resolved by DNS first.

WHAT HAPPENS UNDER THE HOOD

For each packet the firewall finds the most specific matching route. `192.168.10.21` matches the X0 subnet; a public address matches only `0.0.0.0/0` and leaves via X1 to `203.0.113.9`. That route was created for you from X1’s gateway in task 1.1.

Troubleshoot in layers from the firewall’s own Diagnostics: ping the gateway (is the first hop alive?), ping a public address (does routing work?), resolve a name (does DNS work?). Then repeat from a client with `nslookup` to prove the PC side.

LAB VALUES

Default route	`0.0.0.0/0 via X1, gateway 203.0.113.9`
DNS	`1.1.1.1, 8.8.8.8`

THE STEPS, AND WHY EACH ONE

1. **Open POLICY › Rules and Policies › Routing Rules**
   In Classic mode routes live under POLICY, not NETWORK.
2. **Find “Default Route (X1)”: destination 0.0.0.0/0, gateway 203.0.113.9. It was built automatically from X1’s gateway.**
3. **Open NETWORK › DNS › DNS Settings**
4. **Make sure “Servers in use” shows 1.1.1.1 and 8.8.8.8 (inherit from WAN, or specify them and click Accept)** · `1.1.1.1, 8.8.8.8`
5. **Open DEVICE › Diagnostics › Diagnostic Tools**
6. **Ping the ISP gateway from the firewall** · `Ping 203.0.113.9`
   If the gateway does not answer, nothing beyond it will. Check the X1 address, mask and gateway first.
7. **Ping a public address** · `Ping 8.8.8.8`
8. **Resolve a name** · `DNS Name Lookup www.search.example`
   Ping by IP working while names fail is the classic DNS fault.
9. **From ADMIN-PC, run nslookup www.search.example in the PC Console** · `nslookup www.search.example`

How it is verified: Route and DNS are read from the configuration; gateway ping and name lookup are re-run by the simulator from the firewall.

COMMON MISTAKES

- Adding a second “default route” policy with a wrong gateway — the more specific or earlier route wins and breaks things.
- Testing only by IP and declaring the internet working.

IF IT DOES NOT WORK

- Gateway does not answer: compare X1’s gateway with the ISP sheet (203.0.113.9).
- Names fail but IPs work: the firewall has no DNS, or LAN rules block UDP/TCP 53.

KEY TERMS

Route

Destination network + next hop (gateway) + interface.

Default route

0.0.0.0/0, the route of last resort.

DNS

The service that resolves names to addresses.

Next hop

The router a packet is handed to.

> **ON THE JOB**
>
> Gateway, public IP, name: this three-step test is the first thing to run for any "no internet" ticket. It tells you in a minute which layer is broken.

CHECK YOURSELF

1. **Ping 8.8.8.8 works but websites do not open. Likely cause?**
   Answer: DNS. Routing is fine, name resolution is not.
2. **What does 0.0.0.0/0 match?**
   Answer: Every destination not matched by a more specific route.

LEVEL 1 — FRESHER · FRESHER · ABOUT 10 MINUTES

1.3 DHCP server and reservations

The DHCP server leases addresses from a range (scope). A reservation always gives one MAC the same address.

THE SITUATION

Move the X0 scope to 192.168.10.100–192.168.10.199 with the right gateway and DNS, and reserve 192.168.10.50 for PRINTER-01.

WHY IT MATTERS

After task 1.1 the old scope no longer matches X0, so new devices get nothing. Printers and servers need addresses that never change.

WHAT IT ACTUALLY IS

A DHCP scope is the range of addresses the firewall may lease on one interface, together with the options it hands out: gateway, DNS servers and lease time.

After task 1.1 the X0 scope still offers `192.168.168.x`, which no longer matches X0. New devices would get nothing. A reservation ties one MAC address to one IP so devices such as printers always get the same address.

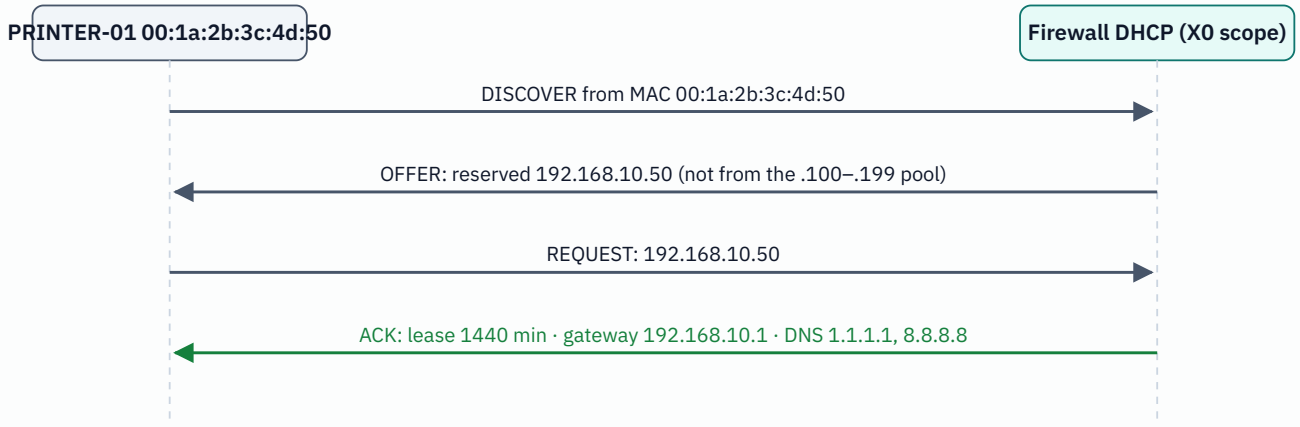


Figure 1.3. The same four-step exchange on the office scope; the printer always receives its reserved address.

WHAT HAPPENS UNDER THE HOOD

The scope `192.168.10.100–.199` leaves `.1–.99` for fixed devices: the firewall (`.1`), ADMIN-PC (`.5`), the printer (`.50`), servers. Lease time 1440 minutes means a PC keeps its address for a day before it must renew.

The reservation matches the printer's MAC `00:1a:2b:3c:4d:50` and always answers it with `192.168.10.50` . It must be outside the dynamic range, otherwise two devices could be given the same

address.

LAB VALUES

Range	`192.168.10.100 – 192.168.10.199`
Lease	`1440 minutes (1 day)`
Gateway	`192.168.10.1`
DNS	`1.1.1.1, 8.8.8.8`
PRINTER-01	`192.168.10.50 ↔ 00:1a:2b:3c:4d:50`

THE STEPS, AND WHY EACH ONE

1. **Open NETWORK › System › DHCP Server**
2. **Notice the X0 scope shows “not serving”: its range is still 192.168.168.x but X0 is now 192.168.10.1/24**
3. **Click Configure on the X0 scope**
4. **Set the range, lease time and gateway** · `Range Start: 192.168.10.100 · Range End: 192.168.10.199 · Lease Time: 1440 · Default Gateway: 192.168.10.1`

   Addresses .2–.99 stay free for static devices like the printer and your PC (.5).
5. **Set the DNS servers clients will use** · `DNS servers: 1.1.1.1, 8.8.8.8`
6. **Click OK**
7. **Click Add Static**
8. **Reserve the printer’s address** · `Entry Name: PRINTER-01 · Static IP: 192.168.10.50 · MAC: 00:1a:2b:3c:4d:50`

   The MAC is on the printer’s label — in the lab, see Lab Tools › Lab Hosts.
9. **Click OK**
10. **Open “Current DHCP Leases” and confirm PRINTER-01 has 192.168.10.50 (Static)**

How it is verified: The scope and reservation are read from the configuration and the simulator recomputes the printer’s lease.

COMMON MISTAKES

- Making the range include .1 or .50.
- Typing the gateway as 192.168.168.168 out of habit.

IF IT DOES NOT WORK

- “not serving”: the range must sit inside the interface subnet.
- Printer gets a pool address: the MAC in the reservation has a typo.

KEY TERMS

Scope

Address range plus options served by DHCP on one interface.

Lease

How long a client may keep its address.

Reservation

A fixed MAC → IP mapping inside DHCP.

MAC address

The hardware address of a network card.

> **ON THE JOB**
>
> Printers, cameras and servers that change address break silently: the print queue still points at the old one. Reserve them, and keep reservations outside the dynamic pool.

CHECK YOURSELF

1. **Why is .50 outside .100–.199?**
   Answer: So the server never offers it to another device.
2. **What gateway should clients get?**
   Answer: 192.168.10.1, the new X0 address.

LEVEL 1 — FRESHER · FRESHER · ABOUT 15 MINUTES

1.4 MAC-IP anti-spoof

Anti-spoof keeps a cache of known IP↔MAC pairs per interface and can drop anything that does not match, or anything from a blacklisted MAC.

THE SITUATION

An unknown laptop has taken FIN-PC's address 192.168.10.22. Prove the problem, record the real pairs from the asset register, blacklist the laptop and enforce on X0.

WHY IT MATTERS

Anyone who can plug in can claim any IP. Without binding, the last device to answer ARP gets the traffic — that is both an outage and an attack.

WHAT IT ACTUALLY IS

On a local network, devices find each other with ARP: "who has 192.168.10.22?" Any device can answer, and the last answer wins. A laptop that claims FIN-PC's address steals its traffic. That is both an outage for Finance and a classic attack (ARP spoofing).

MAC-IP anti-spoof keeps a cache of the correct IP↔MAC pairs per interface and drops traffic that does not match, or that comes from a blacklisted MAC.



Figure 1.4. The cache says which MAC owns each IP; anything else is dropped and logged.

WHAT HAPPENS UNDER THE HOOD

You first prove the problem: FIN-PC's test fails and the ARP table shows `192.168.10.22` belongs to `de:ad:be:ef:00:99`, an unknown vendor. You then record the real pairs from the asset register, blacklist the laptop's MAC, and enable Enforce on X0.

Order matters. If you enforce before your own PC is in the cache, and with Allow Management off, the firewall drops your own traffic: instant lockout. Blacklist by MAC, not IP: an attacker can change IP in seconds.

LAB VALUES

ADMIN-PC	`192.168.10.5 ↔ 00:1a:2b:3c:4d:05`
HR-PC	`192.168.10.21 ↔ 00:1a:2b:3c:4d:21`
FIN-PC	`192.168.10.22 ↔ 00:1a:2b:3c:4d:22`
Blacklist	`de:ad:be:ef:00:99 (unknown laptop)`
X0 flags	`Enable, DHCP Server, ARP Lock, Enforce, Spoof Detection, Allow Management`

THE STEPS, AND WHY EACH ONE

1. **Send a test from FIN-PC to www.search.example (HTTPS) and see it fail**

   The Traffic Tester runs the packet through the simulated firewall and explains each stage.

2. **Open NETWORK › System › ARP**
3. **Find 192.168.10.22: it maps to de:ad:be:ef:00:99 (vendor UNKNOWN), not FIN-PC's 00:1a:2b:3c:4d:22**
4. **Open NETWORK › System › MAC IP Anti-Spoof**
5. **Click Add (cache entry for ADMIN-PC)**
6. **Enter ADMIN-PC's pair** · `Interface: X0 · IP: 192.168.10.5 · MAC: 00:1a:2b:3c:4d:05`
7. **Click OK**
8. **Click Add (cache entry for HR-PC)**
9. **Enter HR-PC's pair** · `Interface: X0 · IP: 192.168.10.21 · MAC: 00:1a:2b:3c:4d:21`
10. **Click OK**
11. **Click Add (cache entry for FIN-PC)**
12. **Enter FIN-PC's pair** · `Interface: X0 · IP: 192.168.10.22 · MAC: 00:1a:2b:3c:4d:22`
13. **Click OK**
14. **Click Add for the unknown laptop**
15. **Enter the laptop's MAC with Blacklisted on** · `Interface: X0 · IP: 192.168.10.22 · MAC: de:ad:be:ef:00:99 · Blacklisted: true`
16. **Click OK**

17 **On the Settings tab, click Configure for X0**

18 **Turn on Enable, DHCP Server, ARP Lock, Enforce (Ingress), Spoof Detection and keep Allow Management** · `Enable: true · DHCP Server: true · ARP Lock: true · Enforce: true · Spoof Detection: true · Allow Management: true`

DHCP Server trusts pairs the firewall handed out itself; ARP Lock stops the rogue overwriting FIN-PC's entry; Allow Management keeps you from locking yourself out.

19 **Click OK**

20 **Test again from the unknown laptop — it must be dropped**

21 **Test from FIN-PC — it must work now**

22 **Open MONITOR › Logs › System Logs**

23 **Find the "MAC-IP anti-spoof" alert for the blacklisted MAC — this is your evidence**

How it is verified: The cache and flags are read from the configuration; the engine re-runs the rogue, FIN-PC and ADMIN-PC flows.

COMMON MISTAKES

- Enforcing before your own PC is in the cache, with Allow Management off — instant lockout.
- Blacklisting by IP instead of MAC: the rogue just picks another address.

IF IT DOES NOT WORK

- FIN-PC still broken: ARP Lock pins FIN's pair, or Enforce drops the rogue — you need at least one with FIN's correct pair cached.
- Locked out: the disconnected screen offers console recovery.

KEY TERMS

ARP

How a device finds the MAC address for an IP on the local network.

ARP spoofing

Answering ARP for an address that is not yours.

Anti-spoof cache

Trusted IP↔MAC pairs the firewall enforces.

Blacklist

MACs that are always dropped.

ON THE JOB

MAC addresses can be spoofed too, so this is one layer, not the whole answer. In larger networks the same idea lives on the switch (port security, 802.1X). The log alert is your evidence for the incident ticket.

CHECK YOURSELF

1. **Why add ADMIN-PC first?**
   Answer: Enforcement drops anything not in the cache, including your management PC.
2. **Why blacklist the MAC and not the IP?**
   Answer: The IP is borrowed; the MAC identifies the device.

LEVEL 1 — FRESHER · FRESHER · ABOUT 15 MINUTES

1.5 Address objects and groups

Address objects give names to hosts, networks, ranges and FQDNs. Groups bundle objects. Rules refer to names, never to raw IPs.

THE SITUATION

Create the four objects the next tasks use, then a group for finance PCs.

WHY IT MATTERS

When an address changes you edit one object, not twenty rules. Names also make rules readable in an audit.

WHAT IT ACTUALLY IS

An address object gives a name to a host, network, range or domain name: `H_WEB-01`, `N_LAN-Staff`, `FQDN_update-site`. A group bundles objects: `G_Finance-PCs`.

Rules then refer to names, not raw numbers. When the web server moves, you edit one object instead of twenty rules, and an auditor reading `N_LAN-Staff → Any` understands it immediately.

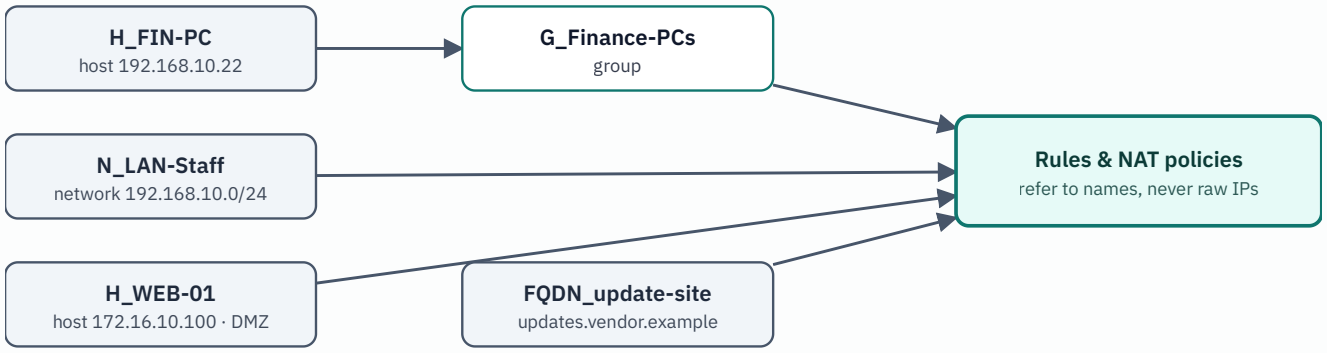


Figure 1.5. Rules point at names; change an address once and every rule follows.

WHAT HAPPENS UNDER THE HOOD

Each object also has a zone. The firewall uses it for zone-aware checks: an object for a LAN host placed in the WAN zone silently fails to match where you expect. A network object must use the network address (`192.168.10.0`), not a host address (`.1`).

An FQDN object is resolved by DNS and follows the address if it changes. A naming convention (H_ host, N_ network, G_ group, FQDN_) makes large rule sets readable.

LAB VALUES

H_WEB-01	`Host 172.16.10.100, zone DMZ`

N_LAN-Staff	`Network 192.168.10.0/255.255.255.0, zone LAN`
FQDN_update-site	`FQDN updates.vendor.example, zone WAN`
H_FIN-PC	`Host 192.168.10.22, zone LAN`
G_Finance-PCs	`contains H_FIN-PC`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Addresses**

   Default objects (X0 IP, X0 Subnet, LAN Subnets…) are created by the firewall from the interfaces; yours are “Custom”.

2. **Click Add for H_WEB-01**

   The DMZ web server, published in task 2.2.

3. **Fill in H_WEB-01** · `Name: H_WEB-01 · Zone: DMZ · Type: host · IP Address: 172.16.10.100`

4. **Click Save**

5. **Click Add for N_LAN-Staff**

   The whole office LAN, used as the source of the first outbound rule.

6. **Fill in N_LAN-Staff** · `Name: N_LAN-Staff · Zone: LAN · Type: network · Network: 192.168.10.0 · Netmask: 255.255.255.0`

7. **Click Save**

8. **Click Add for FQDN_update-site**

   A name, not an IP: the firewall resolves it, so the rule follows the site if its address changes.

9. **Fill in FQDN_update-site** · `Name: FQDN_update-site · Zone: WAN · Type: fqdn · FQDN: updates.vendor.example`

10. **Click Save**

11. **Click Add for H_FIN-PC**

    One finance workstation, placed in a group so more can be added later.

12. **Fill in H_FIN-PC** · `Name: H_FIN-PC · Zone: LAN · Type: host · IP Address: 192.168.10.22`

13. **Click Save**

14. **Open the Address Groups tab and click Add**

15. **Name the group G_Finance-PCs and move H_FIN-PC into it** · `Name: G_Finance-PCs · Members: H_FIN-PC`

16 Click Save

How it is verified: Every object is compared field by field with the plan.

COMMON MISTAKES

- Network object with a host address (192.168.10.1 instead of .0).
- Wrong zone — a LAN object in the WAN zone silently fails zone-aware checks.

IF IT DOES NOT WORK

- “already exists”: names are unique across objects and groups.
- Cannot delete an object: it is still used by a rule or group (see References).

KEY TERMS

Address object

A named host, network, range or FQDN.

Address group

A named set of objects.

FQDN

A full domain name, e.g. updates.vendor.example.

> **ON THE JOB**
>
> Consistent naming is what makes a 500-rule firewall maintainable. Agree a convention with the team and stick to it.

CHECK YOURSELF

1. **Why is 192.168.10.1/24 wrong for N_LAN-Staff?**
   Answer: A network object uses the network address, 192.168.10.0.
2. **Benefit of groups?**
   Answer: Add a new finance PC to the group and every rule using it applies at once.

LEVEL 1 — FRESHER · FRESHER · ABOUT 20 MINUTES

1.6 First access rule and outbound NAT

Access rules decide what may cross from one zone to another, top-down, first match wins. NAT then rewrites the private source to the public WAN address.

THE SITUATION

Allow the staff LAN only web and DNS to the internet, log it, turn off the “allow anything” default, and prove web works while SSH does not.

WHY IT MATTERS

The factory LAN→WAN rule allows every port. Least privilege means allowing what the business needs and logging it.

WHAT IT ACTUALLY IS

Access rules are written between zones (here LAN → WAN). The firewall reads them top-down and stops at the first match. If nothing matches, traffic is denied. The factory LAN → WAN rule allows every port, which is easy but far too open.

NAT (network address translation) rewrites the private source `192.168.10.21` to the public `203.0.113.10` as traffic leaves, because private addresses cannot travel on the internet. Replies come back to `203.0.113.10` and the firewall translates them back.

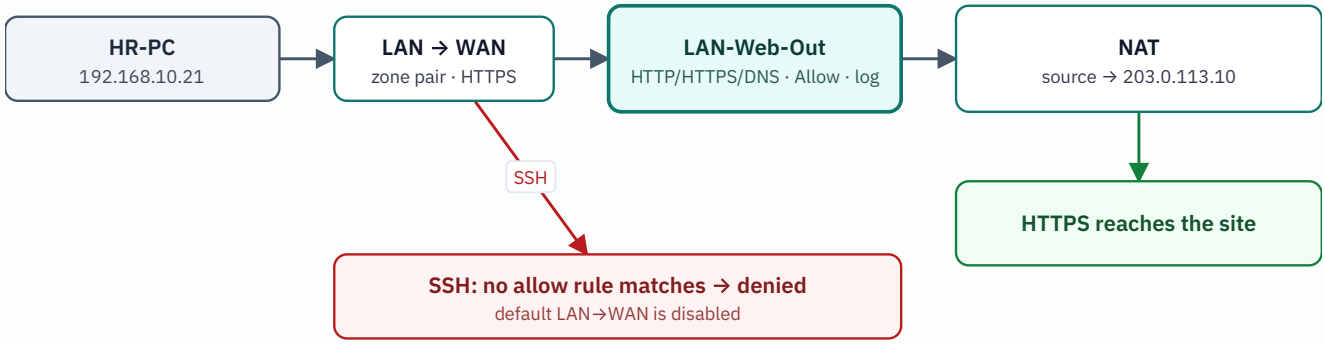


Figure 1.6. The rule decides whether traffic may leave; NAT then gives it the public address.

WHAT HAPPENS UNDER THE HOOD

You build `SG_Web-DNS` (HTTP, HTTPS, DNS) and allow only that from `N_LAN-Staff`, with logging on. Then you disable the factory rule, otherwise it would still allow everything below yours. The Default NAT Policy for X1 already exists; nothing to add.

The proof is two tests: HTTPS is allowed and logged with rule `LAN-Web-Out`; SSH finds no allow rule and is dropped. A rule is only "done" when both the allowed and the refused case are proven.

LAB VALUES

Service group	`SG_Web-DNS = HTTP, HTTPS, DNS (Name Service)`
Rule	`LAN-Web-Out: LAN→WAN, N_LAN-Staff → Any, SG_Web-DNS, Allow, logging on`
Default LAN→WAN	`disabled`
NAT	`Default NAT Policy (X1) enabled`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Services**
2. **Open the Service Groups tab and click Add**
3. **Create SG_Web-DNS with HTTP, HTTPS and DNS (Name Service)** · `Name: SG_Web-DNS · Members: HTTP, HTTPS, DNS (Name Service)`

   DNS (Name Service) is itself a group of TCP 53 and UDP 53. Picking only one of them breaks some lookups.
4. **Click Save**
5. **Open POLICY › Rules and Policies › Access Rules**
6. **Click Add**
7. **Fill in the rule** · `Action: allow · Name: LAN-Web-Out · From: LAN · To: WAN · Source: N_LAN-Staff · Destination: Any · Service: SG_Web-DNS · Logging: true · Enable: true`
8. **Click Add (it goes to the top of LAN→WAN)**
9. **Disable “Default LAN→WAN” with its Enable toggle**

   Otherwise anything your rule does not allow falls through to the default and is allowed anyway.
10. **Open POLICY › Rules and Policies › NAT Rules**
11. **Find “Default NAT Policy (X1)”: private sources leaving X1 become 203.0.113.10. Nothing to add.**
12. **Test HR-PC → www.search.example HTTPS — allowed by LAN-Web-Out**
13. **Test HR-PC → www.search.example SSH — must be refused**
14. **Open MONITOR › Logs › System Logs**
15. **Find the allowed HTTPS entry (rule LAN-Web-Out) and the dropped SSH entry**

How it is verified: The rule, group and NAT state are read from the configuration; the engine re-runs a web flow and an SSH flow.

COMMON MISTAKES

- Picking only “DNS (Name Service) UDP”: some lookups use TCP and fail.
- Leaving the default LAN→WAN enabled, which makes the new rule meaningless.
- Creating the rule WAN→LAN by mistake.

IF IT DOES NOT WORK

- Web test says DNS failure: the rule does not include DNS, or HR-PC’s DNS (1.1.1.1) is blocked.
- SSH still allowed: another enabled LAN→WAN rule above or below matches it.

KEY TERMS

Access rule

Zone pair + source + destination + service + action.

First match wins

Evaluation stops at the first matching rule.

Implicit deny

Anything not allowed is dropped.

Source NAT

Rewriting the private source to a public address.

> **ON THE JOB**
>
> Least privilege: allow what the business needs and log it. DNS uses both UDP and TCP; choosing only UDP breaks large lookups in ways that are hard to diagnose.

CHECK YOURSELF

1. **Your rule is correct but SSH still works. Why?**
   Answer: The factory "allow any" LAN → WAN rule is still enabled.
2. **Does NAT allow traffic?**
   Answer: No. NAT only rewrites addresses; the access rule decides.

LEVEL 2

Junior engineer

Publish, segment, control

Level 2 is the daily work of a junior firewall engineer: opening a port only when needed, publishing a server safely, cleaning up a rule set you inherited, splitting the network into segments, and controlling websites, applications and users.

2.1 Service objects and schedules · ~20 min

2.2 Publish a web server · ~25 min

2.3 Rule order, shadowing and cleanup · ~25 min

2.4 VLANs and segmentation · ~35 min

2.5 Content filtering · ~20 min

2.6 Application control · ~15 min

2.7 Local users and authentication · ~20 min

2.1 Service objects and schedules

Service objects name a protocol and port range; groups bundle them. Schedules make a rule active only at certain times.

THE SITUATION

The SaaS tool uses TCP 8443 plus HTTPS and may only be used in office hours (Mon–Sat 09:00–19:00). Build the objects and a scheduled rule, then test at 10:00 and 21:00.

WHY IT MATTERS

Open only what the business needs, only when it needs it. Outside hours the port is closed — less attack surface, fewer surprises.

WHAT IT ACTUALLY IS

A service object names a protocol and port: `TCP-8443`. A service group bundles them: `SG_SaaS = TCP-8443 + HTTPS`. A schedule makes a rule active only at certain times.

Together they express a business requirement precisely: "staff may use the SaaS tool on its ports, in office hours only".

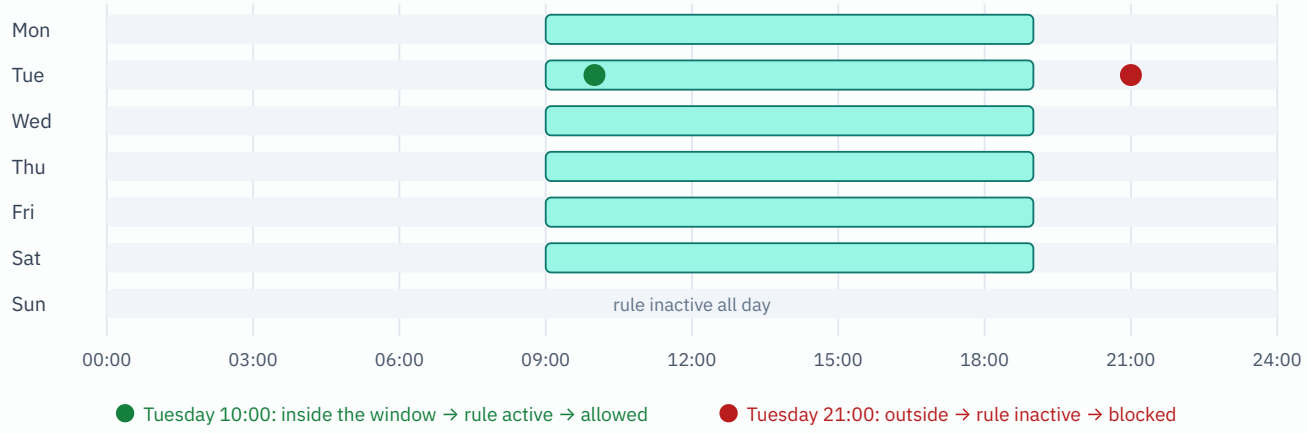


Figure 2.1. Outside the schedule the rule is inactive, so the port is closed.

WHAT HAPPENS UNDER THE HOOD

The schedule `Office-Hours` covers Monday to Saturday, 09:00–19:00, in 24-hour time and in the firewall's time zone. Outside that window the rule does not exist as far as matching is concerned, so traffic falls through to later rules or the implicit deny.

You test both sides with the lab clock: Tuesday 10:00 is allowed, 21:00 is blocked. If a broader rule above already allows TCP 8443, your schedule never takes effect: rule order still applies.

LAB VALUES

Service	`TCP-8443 = TCP 8443`
Group	`SG_SaaS = TCP-8443 + HTTPS`
Schedule	`Office-Hours: Mon–Sat 09:00–19:00`
Rule	`LAN-SaaS-Office-Hours: LAN→WAN, N_LAN-Staff → Any, SG_SaaS, Office-Hours, Allow`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Services**
2. **Click Add (Service Objects)**
3. **Create TCP-8443** · `Name: TCP-8443 · Protocol: TCP · Port start: 8443 · Port end: 8443`
4. **Click Save**
5. **On Service Groups, click Add**
6. **Create SG_SaaS with TCP-8443 and HTTPS** · `Name: SG_SaaS · Members: TCP-8443, HTTPS`
7. **Click Save**
8. **Open OBJECT › Match Objects › Schedules**
9. **Click Add**
10. **Create Office-Hours: Mon–Sat, 09:00 to 19:00** · `Name: Office-Hours · Days (1=Mon … 6=Sat): 1, 2, 3, 4, 5, 6 · Start: 09:00 · End: 19:00`

    Times are in the firewall's time zone (Asia/Kolkata), not your PC's.
11. **Click Save**
12. **Open POLICY › Rules and Policies › Access Rules**
13. **Click Add (rule LAN-SaaS-Office-Hours)**
14. **Fill in LAN-SaaS-Office-Hours** · `Action: allow · Name: LAN-SaaS-Office-Hours · From: LAN · To: WAN · Source: N_LAN-Staff · Destination: Any · Service: SG_SaaS · Schedule: Office-Hours · Logging: true · Enable: true`
15. **Click Add**
16. **Test HR-PC → saas-tool.example TCP 8443 on Tuesday at 10:00 — allowed**

    The Lab time field lets you test any day and time without waiting for it.

17 Test the same at 21:00 — the rule is inactive, so it is blocked

How it is verified: Objects and rule are read from the configuration; the engine evaluates the same flow at 10:00 and 21:00 in the firewall's time zone.

COMMON MISTAKES

- Ticking Sunday.
- Using 7:00 PM as 07:00 — the lab uses 24-hour time.
- Putting the rule below a broader allow that already permits TCP 8443.

IF IT DOES NOT WORK

- Allowed at 21:00: another rule (above or below) also allows TCP 8443 — check every LAN→WAN rule.
- Blocked at 10:00: check the time zone and the days in the schedule.

KEY TERMS

Service object

Protocol + port range.

Service group

A named set of services.

Schedule

Days and hours when a rule is active.

> **ON THE JOB**
>
> Schedules are common for vendor access, backup windows and contractor accounts. Always confirm the firewall clock and time zone; a wrong time zone shifts the window.

CHECK YOURSELF

1. **Why did 21:00 fail?**
   Answer: The rule is inactive outside its schedule, so nothing allows the traffic.
2. **7:00 PM in this lab is…**
   Answer: 19:00.

2.2 Publish a web server

Publishing = an inbound NAT that maps a public IP to a private server, plus an access rule that allows only the service you publish.

THE SITUATION

Put WEB-01 (172.16.10.100) in a DMZ on X2 and publish HTTPS on 203.0.113.11. Nothing else.

WHY IT MATTERS

A server reachable from the internet will be attacked. In a DMZ it cannot reach the LAN, and only HTTPS is exposed.

WHAT IT ACTUALLY IS

Publishing a server means making a private server reachable from the internet. It takes two parts: an inbound NAT that maps a spare public address (`203.0.113.11`) to the private server (`172.16.10.100`), and an access rule that allows only the service you publish.

The server goes in a DMZ, a separate zone on its own port (X2). A public server will be attacked; if it is compromised, the DMZ stops the attacker from walking straight into the office LAN.

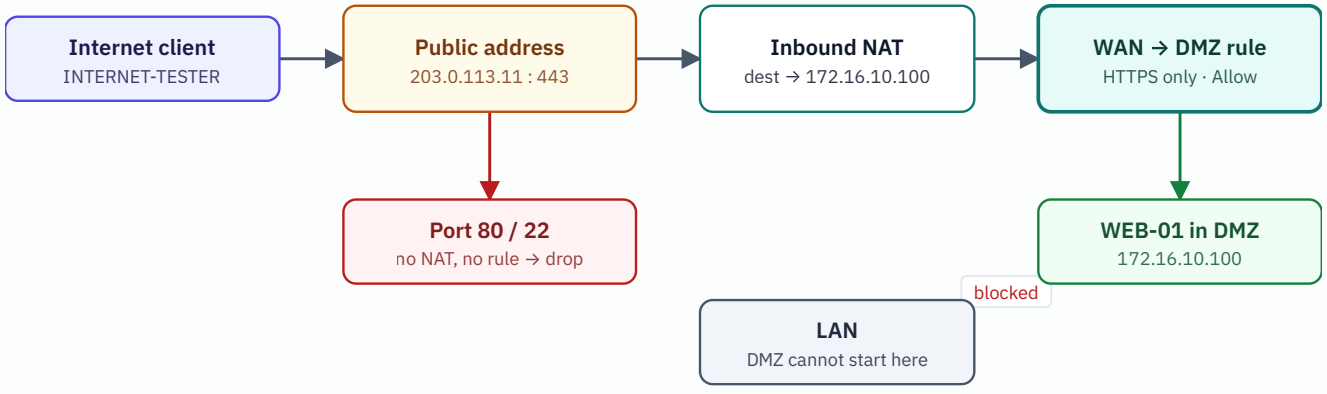


Figure 2.2. Inbound NAT maps the public address to the server; the rule allows only HTTPS.

WHAT HAPPENS UNDER THE HOOD

A request to `203.0.113.11:443` arrives on X1. The NAT policy rewrites the destination to `172.16.10.100` , keeping the port. The WAN → DMZ rule then allows HTTPS to `webserver_public_ip` . Ports 80 and 22 match no NAT and no rule, so they are dropped.

NAT alone allows nothing, and an access rule alone translates nothing: you need both. Translating "Any" service would expose every port on the server.

LAB VALUES

X2	`DMZ, static 172.16.10.1 / 255.255.255.0`
webserver_public_ip	`Host 203.0.113.11, zone WAN`
webserver_private_ip	`Host 172.16.10.100, zone DMZ`
NAT	`webserver_public_ip → webserver_private_ip, HTTPS, inbound X1`
Rule	`WAN→DMZ, Any → webserver_public_ip, HTTPS, Allow`

THE STEPS, AND WHY EACH ONE

1. **Open NETWORK › System › Interfaces**
2. **Click Configure on X2**
3. **Assign X2 to DMZ with a static address** · `Zone: DMZ · Mode: static · IP: 172.16.10.1 · Mask: 255.255.255.0`
4. **Click OK**
5. **Open OBJECT › Match Objects › Addresses**
6. **Click Add for webserver_public_ip**
   The address the internet will use. It is one of the spare addresses in our /29.
7. **Fill in webserver_public_ip** · `Name: webserver_public_ip · Zone: WAN · Type: host · IP Address: 203.0.113.11`
8. **Click Save**
9. **Click Add for webserver_private_ip**
   Where the traffic really goes after translation.
10. **Fill in webserver_private_ip** · `Name: webserver_private_ip · Zone: DMZ · Type: host · IP Address: 172.16.10.100`
11. **Click Save**
12. **Open POLICY › Rules and Policies › NAT Rules**
13. **Click Add**

14 **Build the inbound NAT policy** · `Name: Publish-WEB-01-HTTPS · Original Source: Any · Translated Source: Original · Original Destination: webserver_public_ip · Translated Destination: webserver_private_ip · Original Service: HTTPS · Translated Service: Original · Inbound Interface: X1`

Only the destination is translated. The source stays the real internet client, so logs show who connected.

15 **Click Add**

16 **Open POLICY › Rules and Policies › Access Rules**

17 **Click Add (rule WAN-to-WEB-01-HTTPS)**

NAT only translates. The firewall still needs a rule that allows the traffic.

18 **Fill in WAN-to-WEB-01-HTTPS** · `Action: allow · Name: WAN-to-WEB-01-HTTPS · From: WAN · To: DMZ · Source: Any · Destination: webserver_public_ip · Service: HTTPS · Logging: true · Enable: true`

19 **Click Add**

20 **From INTERNET-TESTER, test https://203.0.113.11 — allowed**

21 **Test HTTP (80) to the same address — refused**

22 **Test SSH (22) — refused**

How it is verified: Configuration is compared with the plan and the engine sends HTTPS, HTTP and SSH from the internet.

COMMON MISTAKES

- Translating “Any” service — every port on WEB-01 becomes reachable.
- Using the firewall’s own WAN address (.10) instead of the spare .11.
- Forgetting the access rule: NAT alone allows nothing.

IF IT DOES NOT WORK

- “NAT mismatch”: the NAT policy exists but not for that service — that is correct for HTTP/SSH.
- “No matching rule” for HTTPS: the WAN→DMZ rule is missing or uses the wrong destination.

KEY TERMS

DMZ

A zone for servers reachable from outside, isolated from the LAN.

Inbound / destination NAT

Public destination rewritten to a private server.

Port forwarding

Common name for publishing one port to an internal host.

ON THE JOB

Every published port is attack surface. Publish only what is needed, keep the server in the DMZ, log the rule, and review published services every quarter.

CHECK YOURSELF

1. **Why not use 203.0.113.10?**
   Answer: That is the firewall's own WAN address; the server uses the spare .11.
2. **You added NAT but the site does not load. What is missing?**
   Answer: The WAN → DMZ access rule.

2.3 Rule order, shadowing and cleanup

Rules are read top-down and the first match wins. A rule that can never match because a broader one sits above it is “shadowed”.

THE SITUATION

You inherit a 10-rule set from a previous admin. Find why the proxy block never works, fix the order, and disable rules that have never been used.

WHY IT MATTERS

Most real firewall breaches involve forgotten or mis-ordered rules, not missing features. Cleanup is routine hygiene.

WHAT IT ACTUALLY IS

Because the first matching rule wins, a rule placed below a broader rule that matches the same traffic can never fire. It is "shadowed": present, enabled, and useless.

Inherited rule sets are full of these, together with rules nobody remembers creating. Hygiene means fixing order and retiring unused rules.

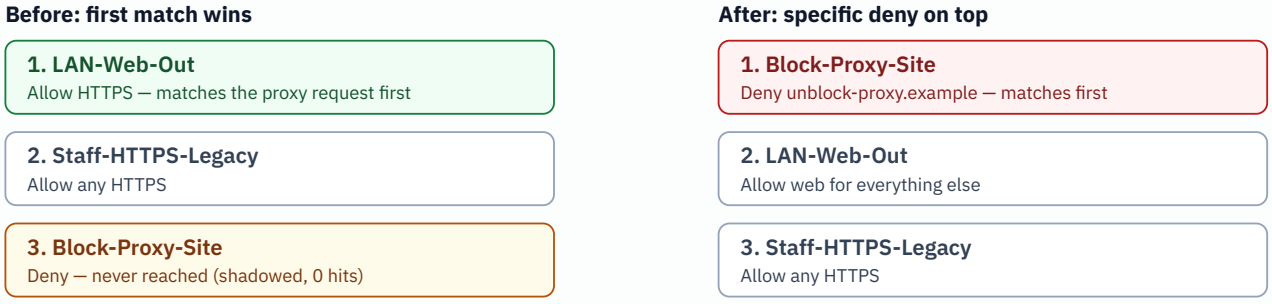


Figure 2.3. A specific deny must sit above the broad allows that would match first.

WHAT HAPPENS UNDER THE HOOD

`Block-Proxy-Site` has 0 hits and a shadowed badge: `LAN-Web-Out` and `Staff-HTTPS-Legacy` above it already allow all HTTPS. You prove it with a test (allowed: wrong), move the block above every allow, and test again (denied).

Hit counters show which rules are used. Rules with 0 hits are disabled first, not deleted: if something breaks, re-enabling is instant. The audit log records each move and disable for the change ticket.

LAB VALUES

Block-Proxy-Site	`priority 1 in LAN→WAN (above every allow rule)`
Disable (0 hits)	`Temp-Vendor-RDP, Old-FTP-Out, Test-Telnet, Allow-POP3-Legacy`
Keep enabled	`every rule that has hits`

THE STEPS, AND WHY EACH ONE

Start with **Start scenario** in the task panel: Load the inherited rule set: 10 LAN→WAN rules, including a block that never fires and several rules with zero hits.

1. **Open POLICY › Rules and Policies › Access Rules**
2. **Find Block-Proxy-Site: it has 0 hits and a “shadowed” badge — Staff-HTTPS-Legacy above it matches all HTTPS first**
3. **Prove it: test HR-PC → unblock-proxy.example HTTPS (it is allowed — wrong)**
4. **Move Block-Proxy-Site above every allow rule (use the up arrow until it is first)**
   A specific deny must sit above any broader allow that also matches its traffic — including LAN-Web-Out and the SaaS rule.
5. **Test again — now denied by Block-Proxy-Site**
6. **Disable the rules with 0 hits: Temp-Vendor-RDP, Old-FTP-Out, Test-Telnet, Allow-POP3-Legacy**
   Disable first, delete later: if something breaks, re-enabling is instant. Rules with hits are in use — leave them.
7. **Open MONITOR › Logs › Auditing Logs**
8. **Your moves and disables are listed with time and user — attach this to the change ticket**

How it is verified: Order, state and hits are read from the configuration; the engine re-evaluates the proxy flow; the audit log is checked for your change.

COMMON MISTAKES

- Moving the block only above Staff-HTTPS-Legacy — LAN-Web-Out above it still wins.
- Deleting rules instead of disabling them first.
- Disabling rules that have hits.

IF IT DOES NOT WORK

- Still allowed: look at the rule named in the test result — it is above your block.
- Hits not increasing: hits count only when traffic is sent (Traffic Tester).

KEY TERMS

Shadowed rule

A rule that can never match because an earlier one always does.

Hit counter

How many connections matched a rule.

Rule hygiene

Regular review of order, usage and ownership.

> **ON THE JOB**
>
> Rule reviews are a standard quarterly task and an audit requirement. Many breaches come from forgotten or mis-ordered rules, not missing features.

CHECK YOURSELF

1. **Why move the block above every allow, not just one?**
   Answer: Any allow above it that matches HTTPS still wins.
2. **Disable or delete unused rules first?**
   Answer: Disable; delete later once nothing complains.

2.4 VLANs and segmentation

VLAN sub-interfaces split one physical port into separate networks, each in its own zone. The switch port must carry the tags (802.1Q trunk).

THE SITUATION

Add VLAN 10 (staff, LAN), 20 (Finance) and 30 (Guest) on X0 with DHCP, trunk the switch port, let guests reach the internet and block guests from Finance.

WHY IT MATTERS

A guest phone on the same flat network as the finance PCs is one exploit away from your accounts. Segmentation contains incidents.

WHAT IT ACTUALLY IS

A VLAN splits one physical network into separate logical networks. The firewall gets a sub-interface per VLAN (`X0:V10` , `X0:V20` , `X0:V30`), each with its own subnet, DHCP scope and zone.

Segmentation contains incidents: a compromised guest phone on its own VLAN cannot reach the finance laptops, because traffic between segments must cross the firewall and its rules.

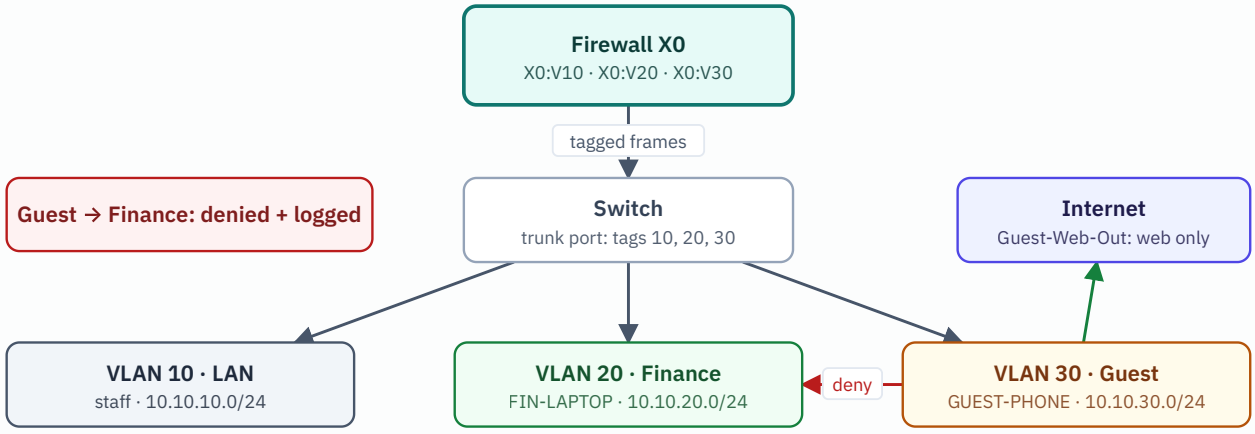


Figure 2.4. One cable carries three networks; zones and rules keep them apart.

WHAT HAPPENS UNDER THE HOOD

Frames carry an 802.1Q tag with the VLAN number. The switch port facing the firewall must be a trunk that carries tags 10, 20 and 30; the ports facing devices are access ports in one VLAN each. If the trunk is missing, everything looks right on the firewall and nothing works.

New zones `Finance` (Trusted) and `Guest` (Public) let you write rules per segment: guests get web only (`Guest-Web-Out`) and Guest → Finance is denied and logged.

LAB VALUES

VLAN 10	`X0:V10, zone LAN, 10.10.10.1/24, DHCP 10.10.10.100–10.10.10.199`
VLAN 20	`X0:V20, zone Finance, 10.10.20.1/24, DHCP 10.10.20.100–10.10.20.199`
VLAN 30	`X0:V30, zone Guest, 10.10.30.1/24, DHCP 10.10.30.100–10.10.30.199`
Zones	`Finance (Trusted), Guest (Public)`
Rules	`Guest-Web-Out (Guest→WAN, SG_Web-DNS, Allow), Guest-to-Finance-Deny (Guest→Finance, Deny, log)`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Zones**
2. **Click Add Zone (Finance)**
3. **Create zone Finance (Trusted)** · `Name: Finance · Security Type: Trusted`
4. **Click Save**
5. **Click Add Zone (Guest)**
6. **Create zone Guest (Public)** · `Name: Guest · Security Type: Public`
7. **Click Save**
8. **Open NETWORK › System › Interfaces**
9. **Click Add Interface (VLAN 10)**
10. **Parent X0, VLAN Tag 10, then Next** · `Parent: X0 · VLAN Tag: 10`
11. **Click Next**
12. **Zone LAN, static 10.10.10.1 / 255.255.255.0** · `name: X0:V10 · Zone: LAN · IP: 10.10.10.1 · Mask: 255.255.255.0`
13. **Click OK**
14. **Click Add Interface (VLAN 20)**
15. **Parent X0, VLAN Tag 20, then Next** · `Parent: X0 · VLAN Tag: 20`
16. **Click Next**

17 **Zone Finance, static 10.10.20.1 / 255.255.255.0** · `name: X0:V20 · Zone: Finance · IP: 10.10.20.1 · Mask: 255.255.255.0`

18 **Click OK**

19 **Click Add Interface (VLAN 30)**

20 **Parent X0, VLAN Tag 30, then Next** · `Parent: X0 · VLAN Tag: 30`

21 **Click Next**

22 **Zone Guest, static 10.10.30.1 / 255.255.255.0** · `name: X0:V30 · Zone: Guest · IP: 10.10.30.1 · Mask: 255.255.255.0`

23 **Click OK**

24 **Open NETWORK › System › DHCP Server**

25 **Click Add Dynamic (scope for VLAN 10)**

26 **Scope on X0:V10: 10.10.10.100–10.10.10.199, gateway 10.10.10.1, DNS 1.1.1.1** · `Interface: X0:V10 · Start: 10.10.10.100 · End: 10.10.10.199 · Gateway: 10.10.10.1 · DNS: 1.1.1.1`

27 **Click OK**

28 **Click Add Dynamic (scope for VLAN 20)**

29 **Scope on X0:V20: 10.10.20.100–10.10.20.199, gateway 10.10.20.1, DNS 1.1.1.1** · `Interface: X0:V20 · Start: 10.10.20.100 · End: 10.10.20.199 · Gateway: 10.10.20.1 · DNS: 1.1.1.1`

30 **Click OK**

31 **Click Add Dynamic (scope for VLAN 30)**

32 **Scope on X0:V30: 10.10.30.100–10.10.30.199, gateway 10.10.30.1, DNS 1.1.1.1** · `Interface: X0:V30 · Start: 10.10.30.100 · End: 10.10.30.199 · Gateway: 10.10.30.1 · DNS: 1.1.1.1`

33 **Click OK**

34 **In Lab Tools › Lab Controls, make the X0 switch port an 802.1Q trunk**

> Without a trunk the switch drops tagged frames and every VLAN host is silent — a very common real-world mistake.

35 **Open POLICY › Rules and Policies › Access Rules**

36 **Click Add (rule Guest-Web-Out)**

37 **Fill in Guest-Web-Out** · `Action: allow · Name: Guest-Web-Out · From: Guest · To: WAN · Source: Any · Destination: Any · Service: SG_Web-DNS · Enable: true`

38 **Click Add**

39 **Click Add (rule Guest-to-Finance-Deny)**

Public zones have no implicit trust, but an explicit, logged deny gives you evidence.

40 **Fill in Guest-to-Finance-Deny** · `Action: deny · Name: Guest-to-Finance-Deny · From: Guest · To: Finance · Source: Any · Destination: Any · Service: Any · Logging: true · Enable: true`

41 **Click Add**

42 **Test GUEST-PHONE → www.search.example HTTPS — allowed**

43 **Test GUEST-PHONE → FIN-LAPTOP SMB — denied and logged**

How it is verified: Interfaces, zones, scopes and rules are compared with the plan; the engine sends guest traffic to the internet and to Finance.

COMMON MISTAKES

- Forgetting the trunk: everything looks right on the firewall and nothing works.
- Putting the Guest VLAN in the LAN zone (trusted) — then it can reach everything.
- Reusing 192.168.20.0/24 — that is the branch office network in task 3.4.

IF IT DOES NOT WORK

- VLAN host “host offline”: check the trunk and that the VLAN interface is enabled.
- Guest gets no lease: the scope must be on the VLAN interface (X0:V30), not on X0.

KEY TERMS

VLAN

A logical network separated by a tag on the same cabling.

802.1Q trunk

A link carrying several tagged VLANs.

Sub-interface

A virtual interface for one VLAN on a physical port.

Segmentation

Dividing a network so a breach stays contained.

ON THE JOB

Guest Wi-Fi, cameras, finance and servers each belong in their own segment. Avoid overlapping subnets: `192.168.20.0/24` is already the branch office in task 3.4.

CHECK YOURSELF

1. **All three VLANs are configured but no device gets an address. First check?**
   Answer: The switch port: it must be an 802.1Q trunk.
2. **Why not put Guest in the LAN zone?**
   Answer: LAN is trusted; guests would reach everything LAN can.

2.5 Content filtering

The content filter rates every website into a category and blocks the categories your policy forbids, showing a block page.

THE SITUATION

Enable CFS, build a CFS_Staff profile that blocks malware, phishing, adult, proxy-avoidance and streaming (but allows video.example for marketing), and apply it to the LAN.

WHY IT MATTERS

Most malware arrives through the browser. Blocking known-bad categories stops it before the PC ever downloads anything.

WHAT IT ACTUALLY IS

The content filter rates every website into a category (Malware, Phishing, Adult, Proxy Avoidance, Streaming…) and blocks categories your policy forbids, showing a block page instead.

Most malware arrives through the browser. Blocking known-bad categories stops it before anything is downloaded.

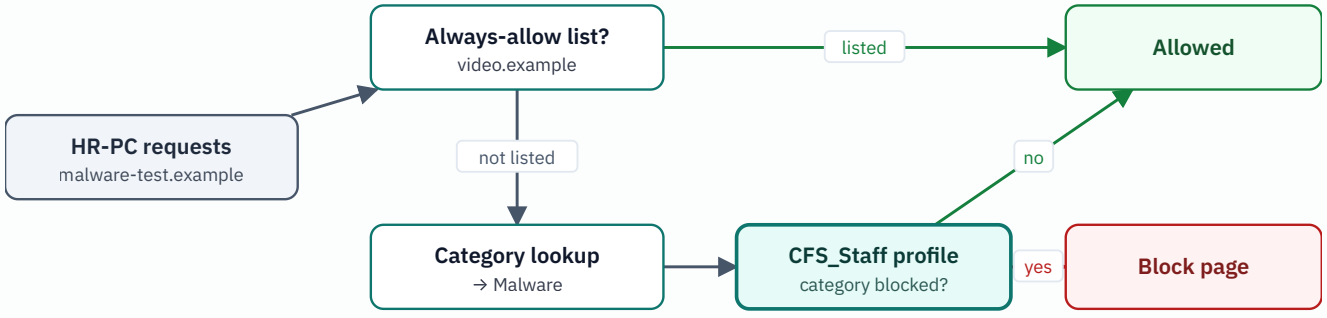


Figure 2.5. Allow list first, then category lookup, then the profile's decision.

WHAT HAPPENS UNDER THE HOOD

Three pieces must exist: the service enabled, a profile (`CFS_Staff`) listing blocked categories and exceptions, and a policy (`CFS-LAN`) applying that profile to a source zone and users. Enabling the service without a policy filters nothing.

The always-allow list wins over categories: `video.example` stays open for marketing even though Streaming is blocked. Test one blocked, one excepted and one normal site.

LAB VALUES

Profile	`CFS_Staff blocks Malware, Phishing, Adult Content, Proxy Avoidance, Streaming Media`
Allow list	`video.example`
Policy	`CFS-LAN: source LAN, users All, profile CFS_Staff`

THE STEPS, AND WHY EACH ONE

1. **Open POLICY › Security Services › Content Filter**
2. **Turn on “Enable Content Filtering Service”**
3. **Open OBJECT › Profile Objects › Content Filter**
4. **Click Add**
5. **Name CFS_Staff, tick the five categories and allow video.example** · `Name: CFS_Staff · Blocked: Malware, Phishing, Adult Content, Proxy Avoidance, Streaming Media · Always allow: video.example`

   The allow list overrides categories: marketing needs video.example even though Streaming Media is blocked.
6. **Click Save**
7. **Open POLICY › Rules and Policies › Content Filter Rules**
8. **Click Add**
9. **Policy CFS-LAN: source zone LAN, users All, profile CFS_Staff** · `Name: CFS-LAN · Source Zone: LAN · Users: All · Profile: CFS_Staff`
10. **Click Save**
11. **Test HR-PC → malware-test.example HTTPS — blocked with a block page**
12. **Test HR-PC → video.example — allowed by the allow list**
13. **Test HR-PC → www.search.example — allowed**

How it is verified: Settings are read from the configuration; the engine checks a blocked category, the allow list and a normal site.

COMMON MISTAKES

- Enabling CFS but creating no policy — nothing is filtered.
- Blocking “Business” or “Search Engines” and breaking work.

IF IT DOES NOT WORK

- Nothing blocked: CFS licensed? enabled? a policy for LAN? the profile has the category?
- Allow list ignored: enter the domain without https:// or paths.

KEY TERMS

Category

A classification of websites by content.

Profile

Which categories to block, plus exceptions.

Allow list

Sites always permitted regardless of category.

> **ON THE JOB**
>
> Agree categories with HR and management in writing. Blocking "Business" or "Search Engines" breaks work and floods the helpdesk.

CHECK YOURSELF

1. **CFS is enabled but nothing is blocked. Why?**
   Answer: No content filter policy applies the profile.
2. **Can CFS see inside HTTPS pages?**
   Answer: It sees the site name; full inspection needs DPI-SSL (task 3.2).

2.6 Application control

App Control identifies applications by their traffic patterns, whatever port they use, and can block or log them by category.

THE SITUATION

Block P2P and proxy/anonymiser apps, and log (not block) social networking so HR can see usage.

WHY IT MATTERS

Tools like UltraSurf tunnel over HTTPS on port 443 to dodge port-based rules and the content filter. Only application identification catches them.

WHAT IT ACTUALLY IS

Port-based rules assume port 443 means "web". Some applications deliberately use 443 to slip through: anonymising proxies such as UltraSurf tunnel over HTTPS to dodge both rules and the content filter.

Application control identifies applications by their traffic patterns, whatever port they use, and acts by category: block, or allow and log.

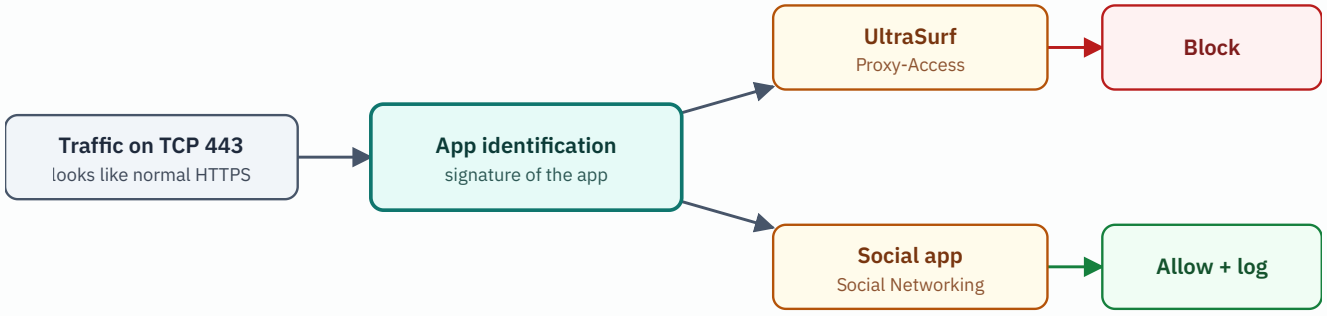


Figure 2.6. Port 443 says nothing; the traffic pattern reveals the application.

WHAT HAPPENS UNDER THE HOOD

You block P2P and Proxy-Access, and log Social Networking. Logging is not weaker than blocking; it is a different requirement. HR asked for visibility, not a ban.

The test with UltraSurf is blocked; the social app is allowed and an "Application Control Detection Alert" appears in the system log as evidence.

LAB VALUES

App Control	`Enabled`

P2P	`Block`
Proxy-Access	`Block`
Social Networking	`Log`

THE STEPS, AND WHY EACH ONE

1. **Open POLICY › Security Services › App Control**
2. **Enable App Control and set the category actions** · `Enable: true · P2P: block · Proxy-Access: block · Social Networking: log`
3. **Click Accept**
4. **Test HR-PC using UltraSurf (Application) to www.search.example — blocked**

   The port is 443 like normal HTTPS, so access rules and CFS let it through — App Control recognises the application itself.
5. **Test HR-PC using the social network app — allowed but logged**
6. **Open MONITOR › Logs › System Logs**
7. **Find “Application Control Detection Alert” for the social app**

How it is verified: Settings are read from the configuration; the engine runs an anonymiser and a social app through the policy.

COMMON MISTAKES

- Blocking Social Networking when the brief says log — HR wanted visibility, not a ban.
- Forgetting App Control is per zone (LAN/WAN have it on by default).

IF IT DOES NOT WORK

- Not blocked: is App Control licensed, enabled, and on for the LAN and WAN zones?

KEY TERMS

Application signature

A pattern identifying an application’s traffic.

Evasive application

Software built to bypass port-based controls.

ON THE JOB

Do exactly what the policy asks. Blocking something the business asked only to monitor creates tickets and erodes trust in the security team.

CHECK YOURSELF

1. **Why can’t a port rule stop UltraSurf?**
   Answer: It uses 443 like normal HTTPS.
2. **Social Networking set to Log: is traffic allowed?**
   Answer: Yes, and every use is recorded.

2.7 Local users and authentication

Rules can match users, not just addresses. Unauthenticated users are redirected to the firewall's login page first.

THE SITUATION

Create the Staff group and two users, require Staff on LAN-Web-Out, then prove an anonymous PC is redirected and a logged-in user browses.

WHY IT MATTERS

IP addresses change hands; people are accountable. User-based rules and logs say who did what.

WHAT IT ACTUALLY IS

IP addresses change hands; people are accountable. A rule can require a user group, so it matches only when the person behind the address has signed in and belongs to that group.

Logs then say "priya browsed X", not "192.168.10.21 browsed X". That is what investigations and audits need.

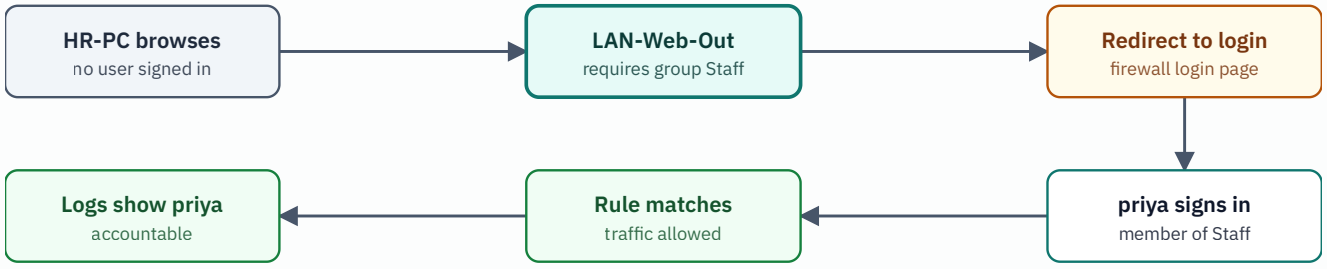


Figure 2.7. Unknown users are sent to log in; members of Staff are allowed and named in the logs.

WHAT HAPPENS UNDER THE HOOD

You create the group `Staff` and users `priya` and `arjun` with practice passwords, then set Users Included = Staff on `LAN-Web-Out`. An anonymous HTTP request is redirected to the firewall's login page; after priya signs in on HR-PC, the same request is allowed.

DEVICE › Users › Status shows who is signed in on which PC. Put the group on the allow rule; a group on a deny rule changes who is denied, not who is allowed.

LAB VALUES

Group	`Staff`
Users	`priya, arjun (members of Staff, practice passwords)`

LAN-Web-Out	`Users Included: Staff`

THE STEPS, AND WHY EACH ONE

1. **Open DEVICE › Users › Local Users & Groups**
2. **On Local Groups, click Add Group**
3. **Name the group Staff** · `Name: Staff`
4. **Click Save**
5. **Click Add User (priya)**
6. **User priya, a practice password, member of Staff** · `Name: priya · Member of: Staff · Password set: true · Passwords match: true`
7. **Click Save**
8. **Click Add User (arjun)**
9. **User arjun, a practice password, member of Staff** · `Name: arjun · Member of: Staff · Password set: true · Passwords match: true`
10. **Click Save**
11. **Open POLICY › Rules and Policies › Access Rules**
12. **Click Configure on LAN-Web-Out**
13. **On the Users tab, set Users Included to Staff** · `name: LAN-Web-Out · Users Included: Staff`
14. **Click Save**
15. **Test HR-PC → www.search.example HTTP with User “(nobody)” — redirected to login**
16. **In Lab Tools › Lab Controls, log priya in on HR-PC** · `HR-PC · priya · the password you set`
17. **Test HR-PC → www.search.example HTTP again (whoever is logged in) — allowed**
18. **Open DEVICE › Users › Status**
19. **See priya logged in on HR-PC**

How it is verified: Users, group and rule are read from the configuration; the engine runs the same flow without and with a Staff user.

COMMON MISTAKES

- Adding users but not to Staff.

- Requiring a group on the deny rule instead of the allow rule.
- Using a real password — this is a lab.

IF IT DOES NOT WORK

- Never redirected: another LAN→WAN allow rule without users matches first (check order).
- Login fails: wrong password; reset it by editing the user.

KEY TERMS

Local user

A user account stored on the firewall.

Group

A set of users that rules can reference.

Captive portal

Redirecting unauthenticated web traffic to a login page.

ON THE JOB

In production users usually come from a directory (LDAP or Active Directory) rather than local accounts, but the rule logic is identical. Check that no other allow rule bypasses the user requirement.

CHECK YOURSELF

1. **Users exist but browsing is still refused. Likely cause?**
   Answer: They are not members of Staff.
2. **Why redirect instead of drop?**
   Answer: So the person can sign in and be identified.

LEVEL 3

Advanced

Inspect threats, connect sites and people

Level 3 adds the features that separate a router from a security gateway: threat signatures, inspection of encrypted traffic, remote access for staff, a tunnel to the branch office, and a second internet link that takes over on its own.

3.1 IPS and gateway anti-virus · ~25 min

3.2 DPI-SSL (TLS inspection) · ~25 min

3.3 SSL VPN for remote users · ~25 min

3.4 Site-to-site IPsec VPN · ~35 min

3.5 Dual WAN with SD-WAN failover · ~30 min

LEVEL 3 — ADVANCED · ADVANCED · ABOUT 25 MINUTES

3.1 IPS and gateway anti-virus

IPS matches traffic against attack signatures; Gateway Anti-Virus scans files in transit. Both act per priority and per zone.

THE SITUATION

Prevent and detect high and medium attacks, detect low, scan HTTP downloads, then handle a false positive with a single, justified signature exclusion.

WHY IT MATTERS

Unpatched systems are attacked within hours of a vulnerability going public. IPS buys time; AV catches known malware at the edge.

WHAT IT ACTUALLY IS

Intrusion prevention (IPS) compares traffic against signatures of known attacks. Gateway anti-virus (GAV) scans files as they pass. Both work at the gateway, before anything reaches the PC.

Signatures carry a priority. Prevent blocks and logs; Detect only logs. A common policy is prevent and detect High and Medium, detect Low, so low-confidence matches do not break business traffic.

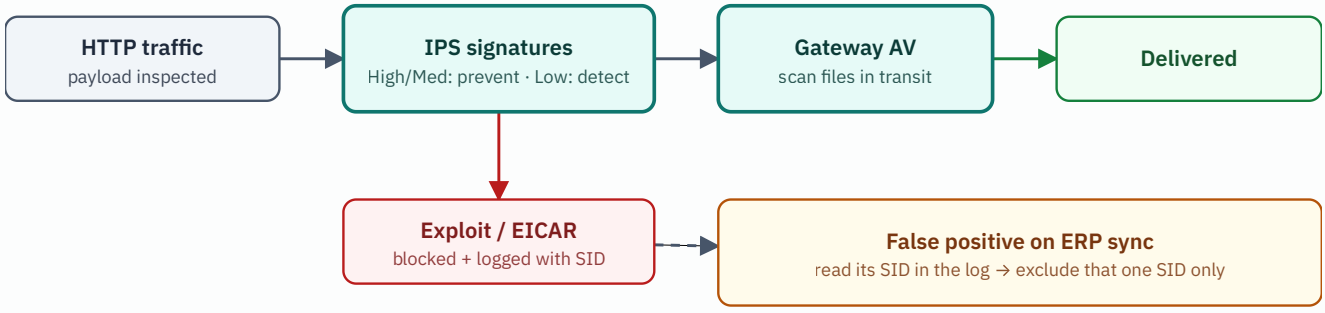


Figure 3.1. Signatures block known attacks; a false positive is fixed with one targeted exclusion.

WHAT HAPPENS UNDER THE HOOD

The simulated exploit is blocked by IPS and the harmless EICAR test file by GAV. EICAR is a standard test string every anti-virus treats as malware; it is not malicious.

Then Finance reports the ERP sync is broken. The log shows an IPS entry for that traffic with a signature ID (SID). The right fix is to exclude that one SID, with the reason recorded. Turning off Medium prevention would "fix" ERP by opening every medium-priority attack.

LAB VALUES

IPS	`High: Prevent + Detect · Medium: Prevent + Detect · Low: Detect`
Gateway AV	`Enabled, HTTP inbound inspection on`
Exclusion	`only the signature that broke the ERP sync (from the log)`

THE STEPS, AND WHY EACH ONE

1. **Open POLICY › Security Services › Intrusion Prevention**
2. **Enable IPS; Prevent + Detect High and Medium; Detect Low** · `Enable IPS: true · high.prevent: true · high.detect: true · medium.prevent: true · medium.detect: true · low.prevent: false · low.detect: true`

   Low-priority signatures produce many false alarms; detect them for visibility but do not block.
3. **Click Accept**
4. **Open POLICY › Security Services › Gateway Anti-Virus**
5. **Enable Gateway Anti-Virus (keep HTTP inbound on)** · `Enable: true`
6. **Click Accept**
7. **Test HR-PC → www.search.example HTTP with Payload “Simulated exploit” — blocked by IPS**
8. **Test an EICAR download over HTTP — blocked by Gateway AV**

   EICAR is a harmless test string every AV engine detects — the lab never uses real malware.
9. **Finance reports the ERP sync is broken: test HR-PC → erp.kaveri-textiles.example HTTP with Payload “ERP sync pattern”**
10. **Open MONITOR › Logs › System Logs**
11. **Find the IPS entry for the ERP traffic and note its SID (signature ID)**

    Never exclude by guesswork — the log tells you exactly which signature fired.
12. **Open POLICY › Security Services › Intrusion Prevention**
13. **Add that SID under Signature exclusions** · `SID excluded: true`
14. **Click Accept**
15. **Test the ERP sync again — allowed**

How it is verified: Settings are read from the configuration and the engine replays the exploit, EICAR and ERP flows.

COMMON MISTAKES

- Disabling Medium prevention to “fix” the ERP app — that opens every medium attack.
- Excluding the exploit signature 2103 instead of the false positive.

IF IT DOES NOT WORK

- Nothing blocked: licensed? enabled globally? IPS/GAV ticked on LAN and WAN zones?
- HTTPS tests are not blocked: without DPI-SSL the engines cannot see inside (task 3.2).

KEY TERMS

Signature / SID

A pattern of a known attack and its ID.

False positive

Legitimate traffic matched as an attack.

EICAR

A harmless standard test file for anti-virus.

> **ON THE JOB**
>
> Every exclusion should name the SID, the application, the requester and a review date. Broad exclusions are how protection erodes.

CHECK YOURSELF

1. **IPS breaks one app. Disable Medium prevention?**
   Answer: No. Exclude only the SID that matched, from the log.
2. **Is EICAR dangerous?**
   Answer: No. It is a harmless test string.

LEVEL 3 — ADVANCED · ADVANCED · ABOUT 25 MINUTES

3.2 DPI-SSL (TLS inspection)

Most traffic is HTTPS, so IPS and AV are blind to it. DPI-SSL decrypts LAN→internet HTTPS, inspects it, and re-encrypts it with the firewall's CA.

THE SITUATION

Prove HTTPS hides an EICAR download, deploy the firewall CA to the PCs, enable client inspection, and exclude banking, health and a certificate-pinned app.

WHY IT MATTERS

Attackers deliver malware over HTTPS precisely because many firewalls cannot see it. Exclusions protect privacy and keep pinned apps working.

WHAT IT ACTUALLY IS

Most traffic is HTTPS, so IPS, AV and the content filter see only encrypted bytes. Attackers deliver malware over HTTPS precisely because many firewalls cannot see it.

DPI-SSL decrypts outgoing HTTPS, inspects it, and re-encrypts it. The PC talks TLS to the firewall; the firewall talks TLS to the website.

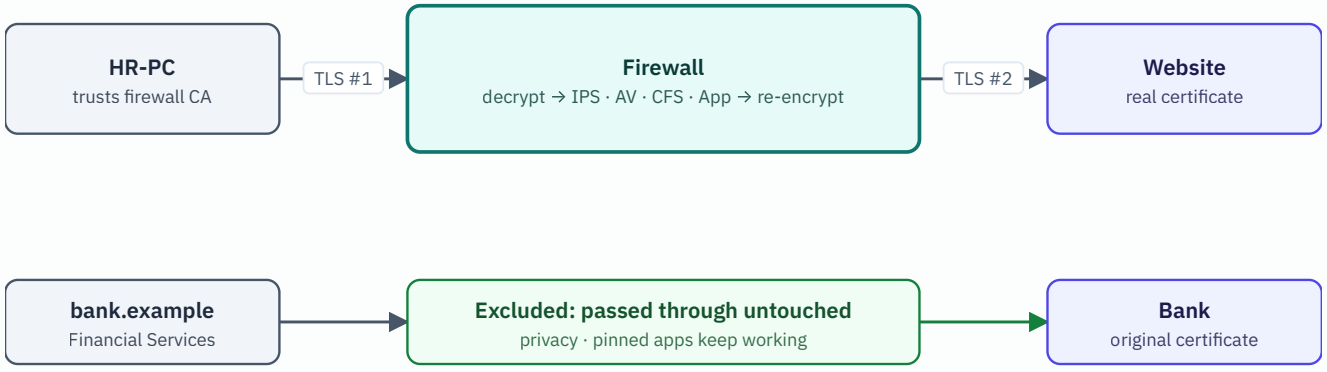


Figure 3.2. Two TLS sessions with inspection in the middle; excluded sites pass untouched.

WHAT HAPPENS UNDER THE HOOD

To do this the firewall issues certificates for the sites on the fly, signed by its own CA. PCs only accept them if that CA is in their trust store, so you deploy it first (as group policy would) and enable inspection second. Doing it the other way round causes certificate errors company-wide.

Exclusions skip decryption: banking and health (privacy and legal reasons) and certificate-pinned apps, which accept only their own certificate and break if inspected. You prove it: HTTPS EICAR blocked after enabling, `bank.example` keeps its original certificate.

LAB VALUES

Client DPI-SSL	`Enabled; inspect IPS, GAV, Anti-Spyware, App Control, CFS`
Excluded categories	`Financial Services, Health`
Excluded names	`pinned-app.example`
Clients	`ThreatWall DPI-SSL CA trusted`

THE STEPS, AND WHY EACH ONE

1. **Test HR-PC → www.search.example HTTPS with Payload EICAR — it gets through (AV is blind)**
2. **Open DEVICE › Settings › Certificates**
3. **Export the "ThreatWall DPI-SSL CA" certificate**
4. **In Lab Tools › Lab Controls, push the CA to the PCs (as group policy would)**
   If you enable inspection first, every HTTPS site shows a certificate error to every user.
5. **Open POLICY › DPI-SSL › Client SSL**
6. **Enable SSL Client Inspection and all five inspection types** · `Enable: true · ips: true · gav: true · spyware: true · appControl: true · cfs: true`
7. **On Objects, exclude Financial Services and Health, and the name pinned-app.example** · `Excluded categories: Financial Services, Health · Excluded names: pinned-app.example`
8. **Click Accept**
9. **Repeat the HTTPS EICAR test — now blocked**
10. **Test HR-PC → bank.example HTTPS — allowed, original certificate (not inspected)**
11. **Test HR-PC → pinned-app.example HTTPS — works thanks to the exclusion**

How it is verified: Configuration and the lab's client trust are read; the engine replays EICAR over HTTPS, a bank site and the pinned app.

COMMON MISTAKES

- Enabling DPI-SSL before deploying the CA — instant certificate errors company-wide.
- Inspecting banking/health sites — privacy and legal exposure.

IF IT DOES NOT WORK

- Certificate errors: is the CA pushed to the PCs?

- An app breaks only with DPI-SSL on: it pins its certificate — exclude its name.

KEY TERMS

TLS inspection

Decrypting, inspecting and re-encrypting HTTPS.

Trust store

The list of CAs a device trusts.

Certificate pinning

An app accepting only one specific certificate.

> **ON THE JOB**
>
> TLS inspection needs a written policy, a privacy review and clear exclusions. Tell users it exists; in many places that is a legal requirement.

CHECK YOURSELF

1. **Why deploy the CA before enabling DPI-SSL?**
   Answer: Otherwise every HTTPS site shows a certificate error.
2. **Why exclude banking?**
   Answer: Privacy and legal exposure; there is little security gain.

3.3 SSL VPN for remote users

SSL VPN (NetExtender) gives a remote laptop an office address from a pool and routes only the networks you list through the tunnel.

THE SITUATION

Create the client pool, enable SSL VPN on WAN port 4433, route only the staff LAN, give priya VPN access with a one-time code, connect, and prove the LAN works while the DMZ does not.

WHY IT MATTERS

Remote access is the front door attackers try first. Least-privilege routes plus MFA limit what a stolen password can reach.

WHAT IT ACTUALLY IS

SSL VPN lets a remote laptop connect to the office over the internet through an encrypted tunnel. The laptop receives an office-side address from a pool and can reach only the networks you list.

Remote access is the door attackers try first, with stolen or guessed passwords. Least-privilege routes plus a one-time code (MFA) limit what a stolen password can reach.

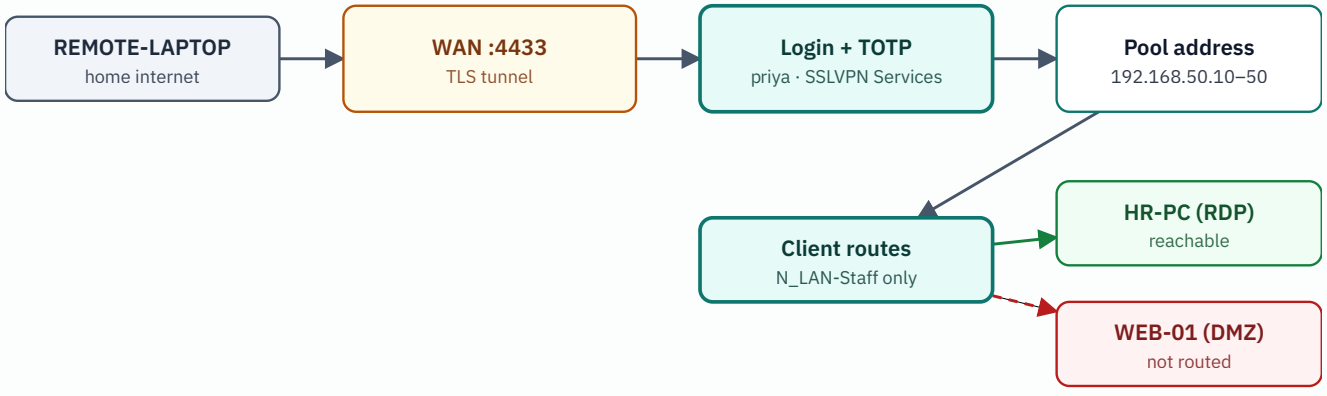


Figure 3.3. The laptop gets a pool address and routes to the staff LAN only.

WHAT HAPPENS UNDER THE HOOD

`SSLVPN_Pool` (`192.168.50.10–.50`) lives in its own SSLVPN zone so VPN users have their own rules. The server listens on the WAN at port 4433. The client route list contains only `N_LAN-Staff` , with tunnel-all off: this is a split tunnel.

priya needs membership of SSLVPN Services and a one-time password. In the lab the code comes from the lab authenticator and the secret is training-only. Tests prove the LAN (RDP to HR-PC) works and the DMZ does not.

LAB VALUES

SSLVPN_Pool	`Range 192.168.50.10–192.168.50.50, zone SSLVPN`
Server	`WAN zone on, port 4433`
Client routes	`N_LAN-Staff only (split tunnel)`
User	`priya: SSLVPN Services + one-time password`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Addresses**
2. **Click Add for SSLVPN_Pool**
3. **SSLVPN_Pool: zone SSLVPN, type Range** · `Name: SSLVPN_Pool · Zone: SSLVPN · Type: range · Start: 192.168.50.10 · End: 192.168.50.50`
4. **Click Save**
5. **Open NETWORK › SSL VPN › Server Settings**
6. **Turn SSL VPN on for WAN and keep port 4433** · `WAN: true · Port: 4433`
7. **Click Accept**
8. **Open NETWORK › SSL VPN › Client Settings**
9. **Pool SSLVPN_Pool, client route N_LAN-Staff only, tunnel-all off** · `Pool: SSLVPN_Pool · Client routes: N_LAN-Staff · Tunnel all: false`

   Hold Ctrl (Cmd on Mac) to pick items in the routes list.
10. **Click Accept**
11. **Open DEVICE › Users › Local Users & Groups**
12. **Click Configure on priya**
13. **Tick SSLVPN Services and Require one-time password** · `Member of: SSLVPN Services, Staff · One-time password: true`
14. **Click Save**
15. **In Lab Tools › Lab Controls › NetExtender, connect as priya with the code from the lab authenticator**
16. **Test REMOTE-LAPTOP → HR-PC (RDP) — allowed through the tunnel**
17. **Test REMOTE-LAPTOP → WEB-01 (HTTPS) — not reachable**

How it is verified: Settings come from the configuration; the engine simulates a connected NetExtender client reaching the LAN and the DMZ.

COMMON MISTAKES

- Tunnel-all or “Any” routes — the laptop gets the whole network.
- Pool in the LAN zone — the SSL VPN zone rules then do not apply.
- Forgetting SSLVPN Services: login works, VPN access is refused.

IF IT DOES NOT WORK

- Portal unreachable: SSL VPN not enabled on WAN, or wrong port.
- “not a member of SSLVPN Services”: edit the user.
- One-time code rejected: codes change every 30 seconds.

KEY TERMS

SSL VPN

Remote access tunnel over TLS.

Address pool

Addresses handed to VPN clients.

Split tunnel

Only listed networks go through the tunnel.

MFA / TOTP

A second factor: a time-based one-time code.

> **ON THE JOB**
>
> Review VPN users monthly, remove leavers the same day, and never route "Any" to remote clients.

CHECK YOURSELF

1. **Login works but VPN access is refused. Why?**
   Answer: The user is not in SSLVPN Services.
2. **Why is WEB-01 unreachable?**
   Answer: The DMZ is not in the client route list.

LEVEL 3 — ADVANCED · ADVANCED · ABOUT 35 MINUTES

3.4 Site-to-site IPsec VPN

A site-to-site tunnel joins two office LANs over the internet. Both firewalls must mirror each other: peer address, key, proposals and networks.

THE SITUATION

Build HQ-to-Branch on HQ (203.0.113.10) and the mirror policy on the Branch firewall (198.51.100.20), bring the tunnel up, and reach HQ from BRANCH-PC.

WHY IT MATTERS

Branches need the ERP and file servers at HQ. A mis-matched setting anywhere keeps the tunnel down — the commonest VPN ticket there is.

WHAT IT ACTUALLY IS

A site-to-site IPsec VPN joins two office networks over the internet, firewall to firewall, so users never start a VPN client. Traffic between `192.168.10.0/24` (HQ) and `192.168.20.0/24` (Branch) is encrypted automatically.

Both firewalls must mirror each other exactly: each one's peer is the other's public address, the shared key is identical, the proposals match, and local and remote networks are swapped.

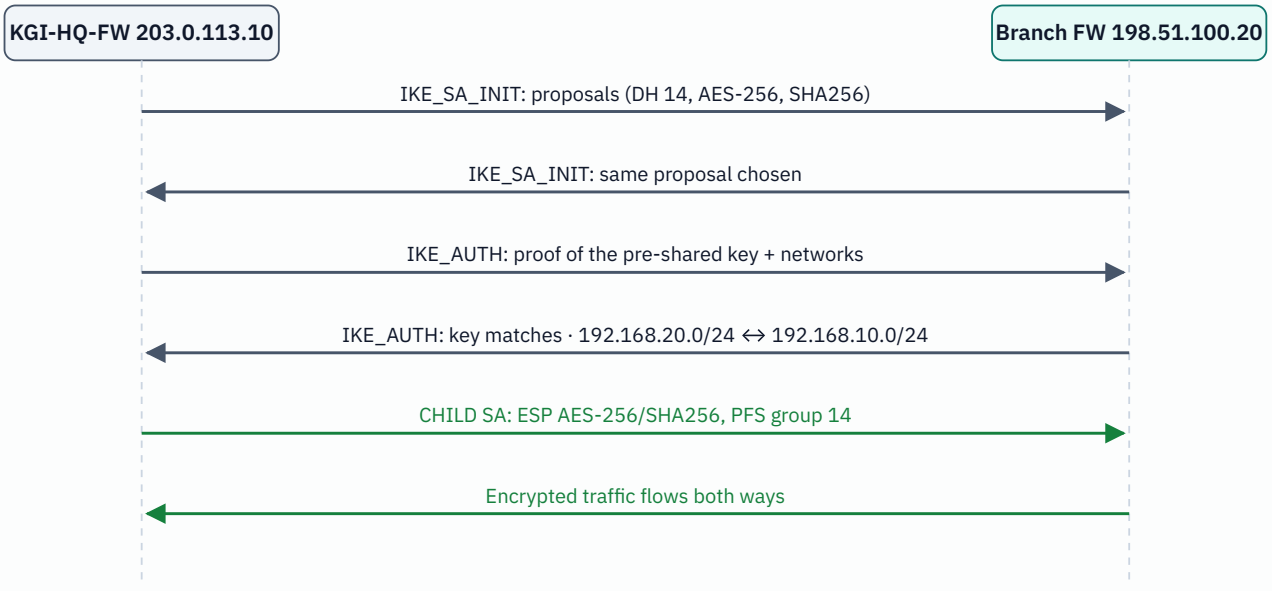


Figure 3.4. Phase 1 builds a secure channel; Phase 2 builds the tunnel for the two LANs.

WHAT HAPPENS UNDER THE HOOD

IKEv2 negotiates in stages. IKE_SA_INIT agrees encryption, hashing and Diffie-Hellman group (Phase 1: DH 14, AES-256, SHA256). IKE_AUTH proves both sides hold the same pre-shared key and states the

networks. A CHILD SA then carries the data (Phase 2: ESP AES-256/SHA256, with PFS group 14 so each tunnel key is fresh).

When you finish HQ alone, the tunnel stays down: there is no peer policy yet, and the log says so. After the Branch mirror is saved, the log shows Phase 1 agreed, authenticated, Phase 2 established, and BRANCH-PC reaches HQ. The shared secret here is training-only.

LAB VALUES

HQ policy	`HQ-to-Branch → 198.51.100.20, N_LAN-Staff ↔ N_Branch-LAN`
Branch policy	`peer 203.0.113.10, X0 Subnet ↔ N_HQ-LAN (192.168.10.0/24)`
Proposals	`IKEv2 · P1 DH 14 / AES-256 / SHA256 · P2 ESP AES-256 / SHA256 · PFS group 14`
Pre-shared key	`a training-only secret of your choice (same on both sides)`

THE STEPS, AND WHY EACH ONE

1. **Open OBJECT › Match Objects › Addresses**
2. **Click Add for N_Branch-LAN**
3. **N_Branch-LAN: zone VPN, Network 192.168.20.0 / 255.255.255.0** · `Name: N_Branch-LAN · zone: VPN · type: network · ip: 192.168.20.0 · ip2: 255.255.255.0`
4. **Click Save**
5. **Open NETWORK › IPSec VPN › Rules and Settings**
6. **Click Add**
7. **General: name, peer gateway and a training-only shared secret (twice)** · `Name: HQ-to-Branch · Gateway: 198.51.100.20 · Secret set: true · Secrets match: true`

   Lab rule: invent a practice key (8+ characters). Never type a real VPN secret into a training tool.
8. **Network tab: local N_LAN-Staff, destination N_Branch-LAN** · `Local network: N_LAN-Staff · Remote network: N_Branch-LAN`
9. **Proposals tab: IKEv2; P1 Group 14 / AES-256 / SHA256; P2 AES-256 / SHA256, PFS Group 14** · `Exchange: ikev2 · P1 DH: Group 14 · P1 Enc: AES-256 · P1 Auth: SHA256 · P2 Enc: AES-256 · P2 Auth: SHA256 · PFS: true · PFS group: Group 14`
10. **Click OK**
11. **The tunnel shows Down: the Branch has no matching policy yet. Read the negotiation log under the table.**

12 **Open NETWORK › IPSec VPN › Branch Peer (lab)**

13 **On the Branch, add address N_HQ-LAN**

14 **N_HQ-LAN: 192.168.10.0 / 255.255.255.0** · `Name: N_HQ-LAN · Network: 192.168.10.0 · Mask: 255.255.255.0`

15 **Click Save**

16 **On the Branch, add the mirror VPN policy**

17 **General: name Branch-to-HQ, peer 203.0.113.10, the same shared secret** · `Name: Branch-to-HQ · Gateway: 203.0.113.10 · Secret set: true · Secrets match: true`

18 **Network: local X0 Subnet, destination N_HQ-LAN** · `Local network: X0 Subnet · Remote network: N_HQ-LAN`

19 **Proposals: identical to HQ** · `Exchange: ikev2 · P1 DH: Group 14 · P1 Enc: AES-256 · P1 Auth: SHA256 · P2 Enc: AES-256 · P2 Auth: SHA256 · PFS: true · PFS group: Group 14`

20 **Click OK**

21 **Open NETWORK › IPSec VPN › Rules and Settings**

22 **HQ-to-Branch shows Up. Read the log: Phase 1 agreed, authenticated, Phase 2 established.**

23 **Test BRANCH-PC → 192.168.10.5 (ping) — allowed through the tunnel**

How it is verified: Both policies are compared with the plan; the simulator negotiates IKE between them and sends traffic from the Branch.

COMMON MISTAKES

- Different keys on each side (AUTHENTICATION_FAILED).
- PFS on one side only (NO_PROPOSAL_CHOSEN).
- Local/remote networks not mirrored (TS_UNACCEPTABLE).

IF IT DOES NOT WORK

- Read the negotiation log: it names the exact stage that failed.
- Peer does not answer: check the gateway addresses (HQ X1 203.0.113.10, Branch 198.51.100.20).

KEY TERMS

IKE

The protocol that negotiates IPsec keys and settings.

Pre-shared key

A secret configured on both peers.

Proposal

Encryption, hash and DH group offered.

PFS

Perfect forward secrecy: fresh keys per tunnel.

> **ON THE JOB**
>
> Agree parameters with the other side in writing before you start, and copy them, never re-type them. A single mismatch keeps the tunnel down.

CHECK YOURSELF

1. **Branch local network is HQ's...**
   Answer: Remote network. They mirror.
2. **What does PFS add?**
   Answer: Each Phase 2 key is independent, so one leaked key does not expose others.

LEVEL 3 — ADVANCED · ADVANCED · ABOUT 30 MINUTES

3.5 Dual WAN with SD-WAN failover

SD-WAN probes each internet link and steers traffic to a healthy one. Link up is not enough: the ISP can fail behind a working cable.

THE SITUATION

Bring up ISP-2 on X3, probe 1.1.1.1 through both links, route internet traffic by an SD-WAN profile, then fail ISP-1 and watch traffic move to X3 and back.

WHY IT MATTERS

A single ISP is a single point of failure for every cloud app, VPN and phone call. Failover must be automatic and tested.

WHAT IT ACTUALLY IS

One ISP is a single point of failure for every cloud app, VPN and call. A second link on X3 helps only if traffic moves to it automatically.

Link state is not enough: the cable to the ISP router can stay up while the ISP's network behind it is down. SD-WAN sends probes through each link and steers traffic by measured health.

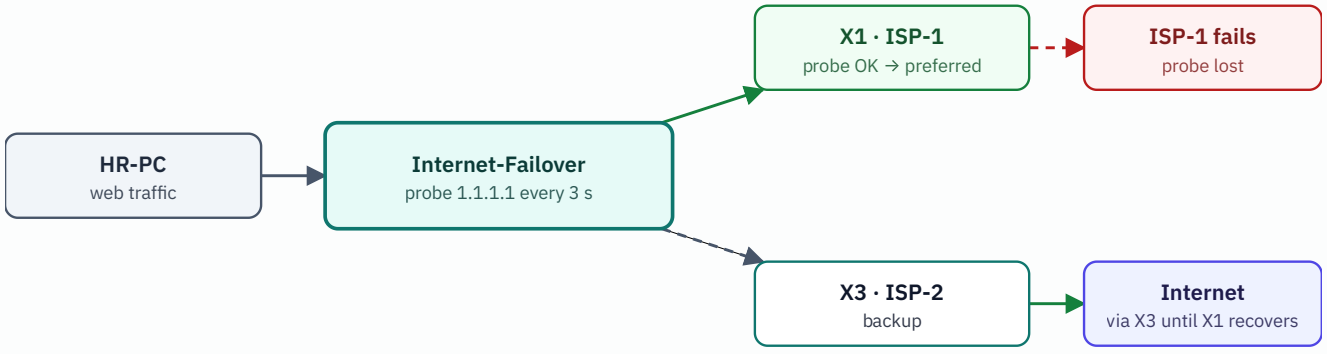


Figure 3.5. The probe, not the cable, decides which link carries traffic.

WHAT HAPPENS UNDER THE HOOD

An SD-WAN group (`WAN-Group` : X1, then X3) lists the links. An SLA probe pings `1.1.1.1` through both every 3 seconds. A path selection profile (`Internet-Failover`) sets the thresholds (≤50 ms, ≤5% loss) and the backup. An SD-WAN route sends Any → Any through that profile.

You fail ISP-1 in Lab Controls: the probe on X1 fails, traffic moves to X3; you restore it and traffic returns. Probe a target beyond the ISP; the ISP gateway itself can answer while the internet behind it is down.

LAB VALUES

X3	`WAN, static 198.51.100.34 / 255.255.255.248, gateway 198.51.100.33, DNS 1.1.1.1/8.8.8.8`
SD-WAN group	`WAN-Group: X1 then X3`
Probe	`Probe-1.1.1.1: ping 1.1.1.1 on X1 and X3, every 3 s`
Profile	`Internet-Failover: WAN-Group, Probe-1.1.1.1, ≤50 ms, ≤5% loss, backup X3`
Route	`SD-WAN route Any → Any using Internet-Failover`

THE STEPS, AND WHY EACH ONE

1. **Open NETWORK › System › Interfaces**
2. **Click Configure on X3**
3. **X3: zone WAN, static ISP-2 address, gateway and DNS (no HTTPS/SSH management)** · `Zone: WAN · Mode: static · IP: 198.51.100.34 · Mask: 255.255.255.248 · Gateway: 198.51.100.33 · DNS 1: 1.1.1.1`
4. **Click OK**
5. **Open NETWORK › SDWAN › SD-WAN Groups**
6. **Click Add**
7. **WAN-Group with X1 first, then X3** · `Name: WAN-Group · Members: X1, X3`
8. **Click Save**
9. **Open NETWORK › SDWAN › SLA Probes**
10. **Click Add**
11. **Probe-1.1.1.1: target 1.1.1.1 from X1 and X3, every 3 s** · `Name: Probe-1.1.1.1 · Target: 1.1.1.1 · Interfaces: X1, X3 · Interval: 3`
12. **Click Save**
13. **Open NETWORK › SDWAN › Path Selection Profiles**
14. **Click Add**
15. **Internet-Failover: WAN-Group, Probe-1.1.1.1, 50 ms, 5%, backup X3** · `Name: Internet-Failover · Group: WAN-Group · Probe: Probe-1.1.1.1 · Latency: 50 · Loss: 5 · Backup: X3`

16 **Click Save**

17 **Open POLICY › Rules and Policies › Routing Rules**

18 **Click Add**

19 **SD-WAN route: name SD-WAN-Internet, Any → Any, type SD-WAN Route, profile Internet-Failover** · `Name: SD-WAN-Internet · Source: Any · Destination: Any · Service: Any · Route Type: sdwan · Profile: Internet-Failover`

20 **Click Add**

21 **Test HR-PC → www.search.example HTTPS — leaves via X1**

22 **In Lab Tools › Lab Controls, fail ISP-1 on X1**

> The cable stays up — only the ISP behind it stops answering. Without a probe the firewall would keep sending traffic into a black hole.

23 **Test again — traffic now leaves via X3**

24 **Restore ISP-1**

25 **Test once more — traffic is back on X1**

How it is verified: Configuration is compared with the plan; the engine evaluates browsing with ISP-1 healthy and failed.

COMMON MISTAKES

- Relying on link state: the cable stays up when the ISP fails.
- Probing the ISP gateway itself (.9) — it can answer while the internet behind it is down.
- Allowing HTTPS management on the new WAN.

IF IT DOES NOT WORK

- No failover: is the route type SD-WAN with the profile? does the probe include X1?
- X3 never used: gateway must be 198.51.100.33.

KEY TERMS

SD-WAN

Policy-based selection between several WAN links.

SLA probe

A regular test measuring reachability, latency and loss.

Failover / failback

Moving to the backup and returning.

ON THE JOB

Test failover on a schedule, not only when the link dies. Keep management closed on the new WAN as on the first.

CHECK YOURSELF

1. **Why not probe 198.51.100.33?**
   Answer: That is the ISP gateway; it can answer while the internet behind it is down.
2. **What decides failover?**
   Answer: Probe results against the profile thresholds.

LEVEL 4

Expert

Run it in production

Level 4 is production: two firewalls acting as one, troubleshooting from evidence instead of guesses, fixing a broken VPN from its log, hardening the box until an auditor has nothing to write, and finally containing a compromised computer.

4.1 High availability · ~25 min

4.2 Packet-flow troubleshooting · ~25 min

4.3 IPsec troubleshooting · ~30 min

4.4 Hardening and audit · ~35 min

4.5 Capstone: contain a compromised host · ~45 min

LEVEL 4 — EXPERT · EXPERT · ABOUT 25 MINUTES

4.1 High availability

Two identical firewalls share one identity: the primary is active, the secondary waits. With stateful sync it already knows every open connection.

THE SITUATION

Pair the secondary unit, monitor the LAN and WAN links, synchronize, then pull the power on the primary and confirm traffic keeps flowing.

WHY IT MATTERS

The firewall is a single point of failure for the whole office. HA turns a hardware fault into a non-event.

WHAT IT ACTUALLY IS

The firewall is a single point of failure for the whole office. High availability pairs two identical units that share one identity: the primary is active, the secondary waits on standby.

With stateful synchronization the standby knows every open connection, so a failover does not drop calls or downloads.

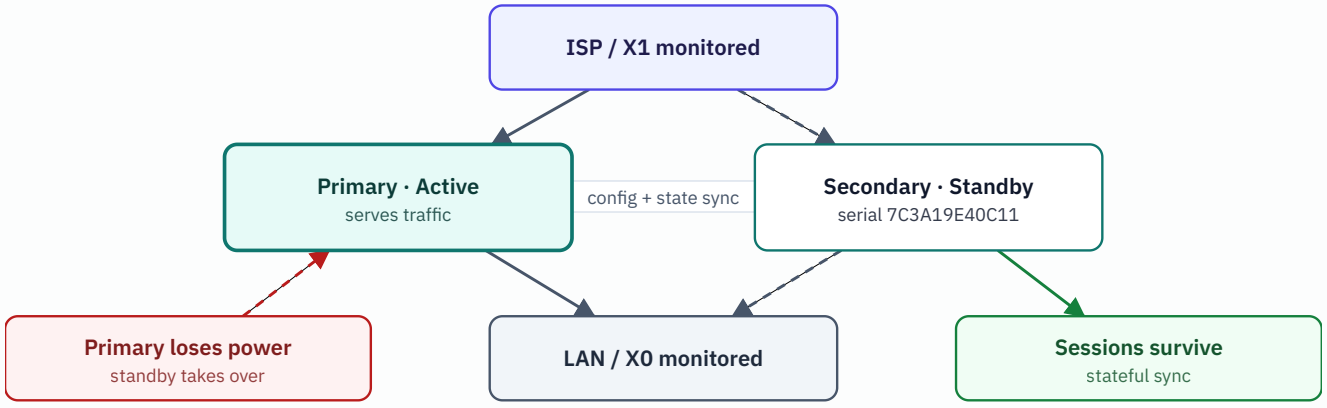


Figure 4.1. The standby already knows the configuration and every open session.

WHAT HAPPENS UNDER THE HOOD

You set Active/Standby with the secondary's serial `7C3A19E40C11`, turn on stateful sync, monitor X0 and X1 (a dead link also triggers failover), and click Synchronize Settings so the standby has the full configuration.

Then you power off the primary in Lab Controls. Traffic continues, served by the secondary. Forgetting to synchronize means the standby comes up with an empty configuration: a failover that causes an outage.

LAB VALUES

Mode	`Active / Standby`
Secondary serial	`7C3A19E40C11`
Stateful sync	`On`
Monitored links	`X0, X1`

THE STEPS, AND WHY EACH ONE

1. **Open DEVICE › High Availability › Settings**
2. **Active/Standby, secondary serial, stateful synchronization on** · `Mode: active-standby · Secondary serial: 7C3A19E40C11 · Stateful sync: true`

   Without stateful sync the standby takes over but every open session (calls, downloads, VPN) drops.
3. **Click Accept**
4. **Open DEVICE › High Availability › Monitoring**
5. **Monitor X0 and X1** · `Monitored: X0, X1`
6. **Click Accept**
7. **Open DEVICE › High Availability › Status**
8. **Click Synchronize Settings**
9. **Test HR-PC → www.search.example HTTPS — served by the primary**
10. **In Lab Tools › Lab Controls, power off the Primary unit**
11. **Test again — still allowed, now served by the secondary**
12. **Power the primary back on**

How it is verified: HA settings are read from the configuration; the engine simulates the primary powered off.

COMMON MISTAKES

- Typing the primary’s own serial as the secondary.
- Forgetting to synchronize: the standby would come up with an empty configuration.

IF IT DOES NOT WORK

- Synchronize is greyed out: check mode, serial, the HA licence and that the secondary is powered.

- Traffic stops when the primary is off: HA not synchronized.

KEY TERMS

Active / Standby

One unit forwards traffic, the other waits.

Stateful sync

Copying the session table to the standby.

Monitored interface

A link whose failure triggers failover.

> **ON THE JOB**
>
> Test failover in a maintenance window at least twice a year, and after firmware upgrades. Both units need the same firmware and licences.

CHECK YOURSELF

1. **Why monitor X1?**
   Answer: If the primary loses the internet link, the standby should take over.
2. **What does stateful sync add?**
   Answer: Existing connections survive the failover.

4.2 Packet-flow troubleshooting

Packet Monitor records what the firewall did with each packet — forwarded, consumed or dropped — and the exact drop reason.

THE SITUATION

After a night change, Finance cannot reach the ERP SaaS while everything else works. Capture the failing flow, read the drop code, fix the cause, capture the success, and write the root cause.

WHY IT MATTERS

Guessing burns hours and causes new outages. A capture turns “it doesn’t work” into one precise line of evidence.

WHAT IT ACTUALLY IS

Packet Monitor records what the firewall did with each packet (forwarded, consumed or dropped) and the exact drop reason. It turns "it doesn’t work" into one precise line of evidence.

Here Finance cannot reach the ERP service after a night change, while everything else works. That pattern means something specific to that destination changed.

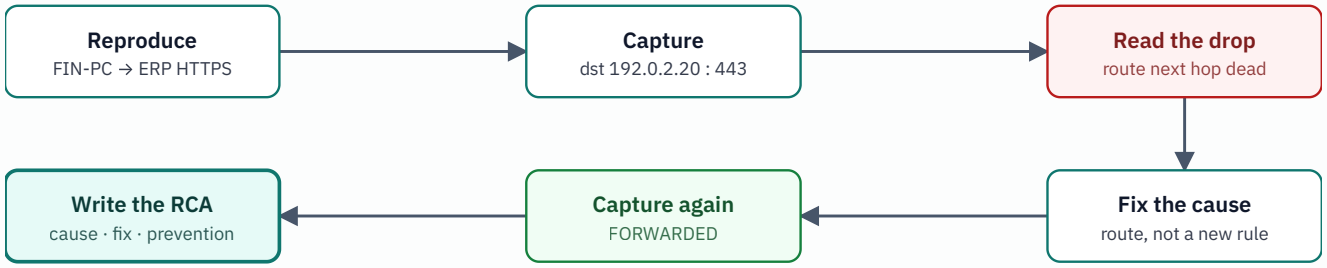


Figure 4.2. Reproduce, capture, read, fix the cause, prove it, write it down.

WHAT HAPPENS UNDER THE HOOD

You reproduce the failure, set a capture filter (destination `192.0.2.20`, port 443) and send the test again. The dropped packet’s reason says the next hop of route `ERP-Legacy-Path` does not answer: the packet was never denied, it was routed into a dead gateway.

So an allow rule would change nothing. You disable the route (or correct its gateway), capture again to see FORWARDED, export the capture, and write the root cause: what changed, why it failed, the fix, and how to prevent it.

LAB VALUES

Failing flow	`FIN-PC → erp.kaveri-textiles.example (192.0.2.20) TCP 443`
Capture filter	`Destination 192.0.2.20, port 443`
Evidence	`one dropped and one forwarded packet, exported`

THE STEPS, AND WHY EACH ONE

Start with **Start scenario** in the task panel: Apply last night's change: Finance reports erp.kaveri-textiles.example times out since this morning.

1. **Reproduce: test FIN-PC → erp.kaveri-textiles.example HTTPS as user arjun**
2. **Open MONITOR › Tools & Monitors › Packet Monitor**
3. **Set the filter: destination 192.0.2.20, port 443** · `Destination: 192.0.2.20 · Port: 443`
4. **Click Start Capture**
5. **Send the same test again while capturing**
6. **Click the DROPPED packet and read its drop code: the next hop of route ERP-Legacy-Path does not answer**
7. **Open POLICY › Rules and Policies › Routing Rules**
8. **Disable ERP-Legacy-Path (or correct its gateway to the ISP router 203.0.113.9)**
9. **Open MONITOR › Tools & Monitors › Packet Monitor**
10. **Test again — the capture now shows FORWARDED**
11. **Export the capture as evidence**
12. **Write the root cause in the task notes below**

How it is verified: The engine replays the ERP flow; evidence and RCA are taken from your recorded actions and notes.

COMMON MISTAKES

- Adding an allow rule — the packet was never denied, it was routed into a dead next hop.
- Deleting the route without recording why (no audit trail for the next admin).

IF IT DOES NOT WORK

- Capture empty: start the capture before sending traffic, and match the filter (dst 192.0.2.20, port 443).

- Still failing after the fix: send the test again — captures only show new packets.

KEY TERMS

Packet capture

A record of packets and the firewall’s decision.

Drop code

The reason a packet was discarded.

Root cause analysis (RCA)

Cause, fix and prevention, written down.

> **ON THE JOB**
>
> Never close an incident on "it works now". Attach the before and after captures and the RCA to the ticket so the next engineer learns from it.

CHECK YOURSELF

1. **Why not add an allow rule?**
   Answer: No rule denied the packet; a route sent it to a dead next hop.
2. **What proves the fix?**
   Answer: A new capture showing FORWARDED for the same flow.

LEVEL 4 — EXPERT · EXPERT · ABOUT 30 MINUTES · SCENARIO TASK

4.3 IPsec troubleshooting

IKE negotiates in stages: reach the peer, agree Phase 1, authenticate, agree Phase 2 and traffic selectors. The log names the stage that failed.

THE SITUATION

The Branch admin changed three things last night and the tunnel is down. Use the negotiation log to find and fix each fault in order, recording the cause of each.

WHY IT MATTERS

VPN outages are the commonest escalation. Reading IKE messages beats re-typing everything and hoping.

WHAT IT ACTUALLY IS

When a tunnel is down, the IKE log names the stage that failed. Reading it beats re-typing every setting and hoping.

The Branch admin changed three things overnight. Each fault hides the next: you fix them one at a time, in the order the negotiation reaches them.

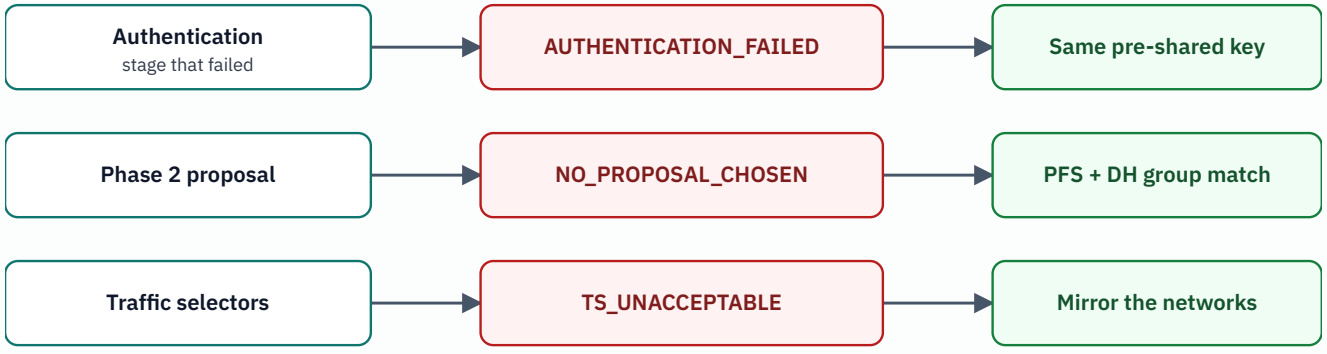


Figure 4.3. Each IKE stage has its own error message and its own fix.

WHAT HAPPENS UNDER THE HOOD

`AUTHENTICATION_FAILED` : Phase 1 agreed but the keys differ. Re-enter the same training secret on the Branch. `NO_PROPOSAL_CHOSEN` at Phase 2: PFS is off on one side; turn it on with DH group 14. `TS_UNACCEPTABLE` : the traffic selectors (networks) do not mirror; set the Branch destination back to `N_HQ-LAN` .

Fix the side that changed. Changing HQ to match a wrong Branch setting would spread the error and break other tunnels that use the same settings.

LAB VALUES

Fault 1	`AUTHENTICATION_FAILED → pre-shared key`
Fault 2	`NO_PROPOSAL_CHOSEN → Phase 2 / PFS`
Fault 3	`TS_UNACCEPTABLE → networks`

THE STEPS, AND WHY EACH ONE

Start with **Start scenario** in the task panel: Apply the Branch admin's overnight change: the HQ↔Branch tunnel drops.

1. **Reproduce: BRANCH-PC → 192.168.10.5 (ping)**
2. **Open NETWORK › IPSec VPN › Rules and Settings**
3. **Read the IKE log: authentication failed — the keys differ**
4. **Record fault 1 in the notes**
5. **Open NETWORK › IPSec VPN › Branch Peer (lab)**
6. **Edit the Branch policy and re-enter the same shared secret as HQ (both fields), then OK**
7. **Open NETWORK › IPSec VPN › Rules and Settings**
8. **Read the log again: authentication passes, Phase 2 now fails with NO_PROPOSAL_CHOSEN**
9. **Record fault 2**
10. **Open NETWORK › IPSec VPN › Branch Peer (lab)**
11. **On the Branch policy's Proposals tab, turn PFS on with DH Group 14, then OK**
12. **Open NETWORK › IPSec VPN › Rules and Settings**
13. **Read the log: TS_UNACCEPTABLE — the Branch expects the wrong HQ network**
14. **Record fault 3**
15. **Open NETWORK › IPSec VPN › Branch Peer (lab)**
16. **On the Branch policy's Network tab, set the destination back to N_HQ-LAN, then OK**
17. **Test BRANCH-PC → 192.168.10.5 again — allowed**

How it is verified: IKE is renegotiated from both configurations; notes are part of the evidence.

COMMON MISTAKES

- Changing HQ to match a wrong Branch setting — fix the side that changed.
- Fixing all three blindly without reading which stage failed.

IF IT DOES NOT WORK

- Reason still AUTHENTICATION_FAILED: retype the key on both fields; it is case-sensitive.
- TS_UNACCEPTABLE: compare HQ local/remote with Branch remote/local — they must mirror exactly.

KEY TERMS

Traffic selector

The local/remote networks a tunnel carries.

NO_PROPOSAL_CHOSEN

No common encryption/PFS settings.

TS_UNACCEPTABLE

The networks do not match.

> **ON THE JOB**
>
> VPN outages are among the commonest escalations. Record each fault and its fix in the ticket; the other side will ask what you found.

CHECK YOURSELF

1. **Which error means the keys differ?**
   Answer: AUTHENTICATION_FAILED.
2. **Why fix the Branch, not HQ?**
   Answer: The Branch is the side that changed.

4.4 Hardening and audit

Hardening closes the doors a working firewall still leaves open: who can log in, from where, how, and what evidence is kept.

THE SITUATION

Rename the admin, require TOTP and lockout, move HTTPS management to port 4443 with an internal-CA certificate, ship logs to syslog, schedule exports, review firmware — until the audit sheet is all green.

WHY IT MATTERS

Auditors and attackers check the same list. Each item here is a finding in a real assessment.

WHAT IT ACTUALLY IS

Hardening closes the doors a working firewall still leaves open: who can log in, from where, how, and what evidence is kept.

Auditors and attackers read the same checklist. Each item here is a finding in a real assessment.

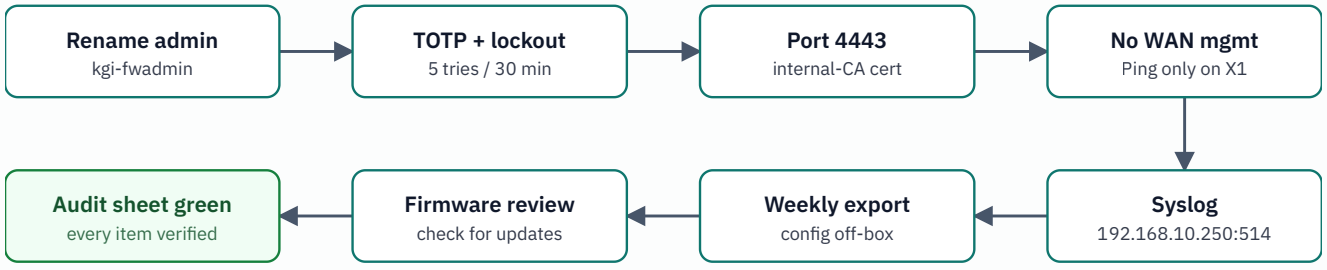


Figure 4.4. Each item closes one door an auditor or attacker would check.

WHAT HAPPENS UNDER THE HOOD

Rename the admin (`kgi-fwadmin`) so the account name is not guessable, require TOTP, and lock out after 5 failures for 30 minutes. Move HTTPS management to 4443 with a certificate from the internal CA, so the browser trusts it and the warning from task 0.2 is gone. Your session ends when the port changes; browse to `https://192.168.10.1:4443` .

Ship logs to syslog (`192.168.10.250:514`) so evidence survives if the box is wiped, schedule weekly exports, check firmware, and review the audit log. The audit sheet turns green item by item.

LAB VALUES

Admin name	`kgi-fwadmin`
Login	`TOTP on; lockout after 5 failures for 30 minutes`

HTTPS port	`4443`
Certificate	`imported internal-CA certificate`
Syslog	`192.168.10.250:514`
Export	`weekly`

THE STEPS, AND WHY EACH ONE

1. **Open DEVICE › Settings › Administration**
2. **Rename the administrator to kgi-fwadmin and set One-time Passwords Method to TOTP** · `Login name: kgi-fwadmin · OTP method: totp`

   After this, every admin login asks for the 6-digit code from the lab authenticator (Lab Tools › Lab Controls).
3. **On Login / Multiple Administrators: enable lockout, 5 attempts, 30 minutes** · `Lockout: true · Attempts: 5 · Minutes: 30`
4. **Click Accept**
5. **Open DEVICE › Settings › Certificates**
6. **Click Import and import the internal-CA certificate for the firewall**
7. **Click Import**
8. **Open DEVICE › Settings › Administration**
9. **On Management: certificate = the imported one, HTTPS port 4443** · `HTTPS port: 4443`
10. **Click Accept — your session ends because the port changed**
11. **Browse to the new address with the port** · `https://192.168.10.1:4443`
12. **Sign in as kgi-fwadmin with your password and the one-time code**

    No certificate warning this time: the PCs trust the internal CA that issued the new certificate.
13. **Open DEVICE › Log › Syslog**
14. **Enable syslog to 192.168.10.250 port 514** · `Enable: true · Server: 192.168.10.250 · Port: 514`
15. **Click Accept**
16. **Click “Send test message”**
17. **Open DEVICE › Settings › Firmware and Settings**

18 **On the Settings tab, click “Check for updates”**

19 **Set Scheduled configuration export to Weekly**

20 **Open MONITOR › Logs › Auditing Logs**

21 **Review today’s changes in the audit log, then check the audit sheet in Verification below**

How it is verified: The audit sheet is evaluated from the live configuration — every line must pass.

COMMON MISTAKES

- Changing the port and forgetting it: note it in the admin runbook.
- Enabling TOTP without access to the authenticator — test in a second session first.

IF IT DOES NOT WORK

- Locked out after the port change: browse to https://192.168.10.1:4443.
- Code rejected: TOTP codes change every 30 seconds — use the current one.

KEY TERMS

Hardening

Reducing attack surface and adding evidence.

Syslog

Sending logs to a central server.

Account lockout

Blocking login after repeated failures.

ON THE JOB

Write the new port and admin name in the runbook the moment you change them. Test TOTP in a second session before closing your first one.

CHECK YOURSELF

1. **Why send logs off the box?**
   Answer: An attacker or a failure on the firewall cannot erase them.
2. **Why does the certificate warning disappear?**
   Answer: The new certificate comes from a CA the PCs already trust.

LEVEL 4 — EXPERT · EXPERT · ABOUT 45 MINUTES · SCENARIO TASK

4.5 Capstone: contain a compromised host

Incident response on the firewall: identify the beaconing host from logs, block the command-and-control destination, quarantine the host, preserve evidence and report.

THE SITUATION

A SOC alert says a workstation contacts an unknown domain every five minutes. Find it, block cdn-update-check.example (192.0.2.66) for everyone, isolate the host, capture proof and write the incident report.

WHY IT MATTERS

A beacon is a compromised machine asking for instructions. Minutes matter: contain first, investigate second, and keep the evidence intact.

WHAT IT ACTUALLY IS

A beacon is a compromised computer checking in with its controller (command-and-control, C2) at regular intervals, asking for instructions. Minutes matter: contain first, investigate second, and keep the evidence intact.

Everything here is synthetic: the alert, the logs and the C2 address `192.0.2.66` (a documentation range). No real destination is ever contacted.

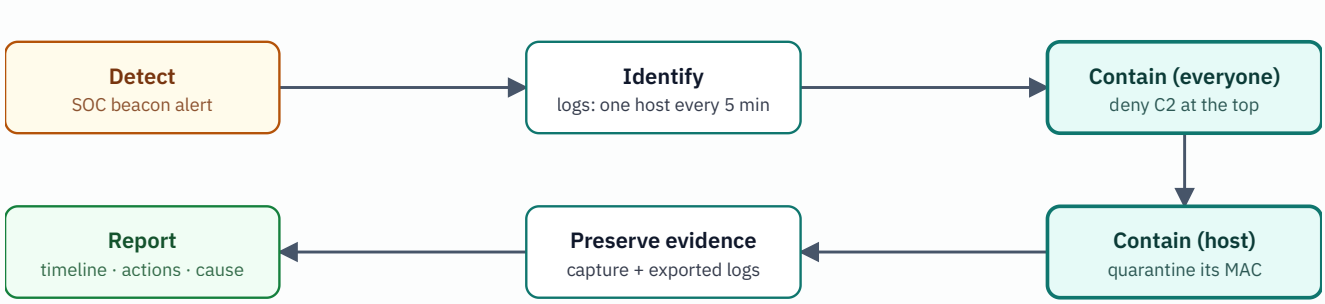


Figure 4.5. Contain first, then preserve evidence, then report.

WHAT HAPPENS UNDER THE HOOD

Search the logs for `cdn-update-check.example` : one source connects every five minutes through an old rule. Block the C2 for everyone with a logged deny above every allow, because other hosts may be infected too; enable the botnet filter as a second layer; quarantine the laptop by blacklisting its MAC on its interface.

Prove containment (the laptop is dropped, FIN-PC is blocked too), capture and export the evidence, and write the report: timeline, containment actions, likely root cause and next steps. Do not wipe the laptop before evidence is preserved.

LAB VALUES

C2 object	`H_C2-Server = 192.0.2.66 (zone WAN)`
Block rule	`LAN→WAN, Any → H_C2-Server, Any, Deny, logging, above every allow`
Quarantine	`blacklist the host's MAC with anti-spoof on its interface`
Evidence	`packet capture + exported logs + report`

THE STEPS, AND WHY EACH ONE

Start with **Start scenario** in the task panel: Inject the SOC alert: synthetic beacon logs from one workstation to a documentation-range address. No real C2 is ever contacted.

1. **Open MONITOR › Logs › System Logs**
2. **Search the logs for cdn-update-check.example: one source connects every 5 minutes via an old rule**
3. **Write the affected host (name and IP) in the report notes**
4. **Open OBJECT › Match Objects › Addresses**
5. **Click Add for H_C2-Server**
6. **H_C2-Server: zone WAN, host 192.0.2.66** · `Name: H_C2-Server · Zone: WAN · Type: host · IP: 192.0.2.66`
7. **Click Save**
8. **Open POLICY › Rules and Policies › Access Rules**
9. **Click Add**
10. **Block-C2-Outbound: Deny, LAN→WAN, Any → H_C2-Server, Any, logging, Position top** · `Action: deny · Name: Block-C2-Outbound · From: LAN · To: WAN · Source: Any · Destination: H_C2-Server · Service: Any · Logging: true`
11. **Click Add**
12. **Open POLICY › Security Services › Botnet Filter**
13. **Enable the Botnet Filter as a second layer**
14. **Open NETWORK › System › MAC IP Anti-Spoof**
15. **On Settings, configure the host's interface X0:V10**

16 **Enable anti-spoof and Spoof Detection on X0:V10** · `Enable: true · Spoof Detection: true`

17 **Click OK**

18 **On Anti-Spoof Cache, click Add**

19 **Interface X0:V10, the host's IP and MAC (Lab Hosts), Blacklisted on** · `Interface: X0:V10 · MAC: 00:1a:2b:10:00:11 · Blacklisted: true`

20 **Click OK**

21 **Open MONITOR › Tools & Monitors › Packet Monitor**

22 **Filter source = the host's IP and Start Capture**

23 **Test STAFF-LAPTOP → cdn-update-check.example HTTPS — dropped (quarantined)**

24 **Test FIN-PC → cdn-update-check.example as arjun — blocked for everyone**

25 **Export the capture**

26 **Open MONITOR › Logs › System Logs**

27 **Search cdn-update-check.example and export the matching logs**

28 **Report: Timeline (first seen, interval, when contained)**

29 **Report: Containment actions taken**

30 **Report: Likely root cause / how it got out**

31 **Report: Next steps (forensics, re-image, monitoring)**

32 **Open your training record (award icon at the top of this panel)**
The record is generated from your actual results: every check is re-run now, and failed attempts are shown as they happened.

How it is verified: Containment is proven by the engine (C2 blocked, host isolated); evidence comes from your exports; the report from your notes.

COMMON MISTAKES

- Blocking only the infected host — the C2 must be blocked for everyone.
- Putting the block below the legacy allow rule.
- Wiping the laptop before capturing evidence.

IF IT DOES NOT WORK

- Block not working: check rule order in LAN→WAN.
- Quarantine not working: anti-spoof must be enabled on X0:V10, the laptop's interface, not X0.

KEY TERMS

C2 (command and control)

The server malware contacts for instructions.

Beaconing

Regular, automated check-ins to a C2.

Containment

Stopping spread and communication without destroying evidence.

> **ON THE JOB**
>
> In a real incident you work with the SOC and follow the incident plan. The firewall is often the fastest place to contain: one rule protects every host at once.

CHECK YOURSELF

1. **Why block the C2 for everyone, not only the infected host?**
   Answer: Other machines may be infected and not yet detected.
2. **Why not re-image the laptop first?**
   Answer: It destroys evidence needed to find the root cause.

Glossary

802.1Q trunk

A link carrying several tagged VLANs.

Accept / OK

The buttons that actually save a change.

Access rule

Zone pair + source + destination + service + action.

Account lockout

Blocking login after repeated failures.

Active / Standby

One unit forwards traffic, the other waits.

Address group

A named set of objects.

Address object

A named host, network, range or FQDN.

Address pool

Addresses handed to VPN clients.

Allow list

Sites always permitted regardless of category.

Anti-spoof cache

Trusted IP↔MAC pairs the firewall enforces.

Application signature

A pattern identifying an application’s traffic.

ARP

How a device finds the MAC address for an IP on the local network.

ARP spoofing

Answering ARP for an address that is not yours.

Audit log

A record of configuration changes: who, what, when.

Authentication code

A second code proving you hold that unit.

Beaconing

Regular, automated check-ins to a C2.

Blacklist

MACs that are always dropped.

Breadcrumb

The path to the current page.

C2 (command and control)

The server malware contacts for instructions.

Captive portal

Redirecting unauthenticated web traffic to a login page.

Category

A classification of websites by content.

Certificate

A signed statement: "this key belongs to this name".

Certificate authority (CA)

An issuer that browsers trust to sign certificates.

Certificate pinning

An app accepting only one specific certificate.

Containment

Stopping spread and communication without destroying evidence.

Default credentials

The factory username and password, public for every unit.

Default route

0.0.0.0/0, the route of last resort.

DHCP

Automatic address assignment: discover, offer, request, acknowledge.

DMZ

A zone for servers reachable from outside, isolated from the LAN.

DNS

The service that resolves names to addresses.

Drop code

The reason a packet was discarded.

EICAR

A harmless standard test file for anti-virus.

Evasive application

Software built to bypass port-based controls.

Export

A configuration file stored off the appliance.

Failover / failback

Moving to the backup and returning.

False positive

Legitimate traffic matched as an attack.

First match wins

Evaluation stops at the first matching rule.

FQDN

A full domain name, e.g. updates.vendor.example.

Group

A set of users that rules can reference.

Hardening

Reducing attack surface and adding evidence.

Hit counter

How many connections matched a rule.

Hostname

The device name used in logs, alerts and backups.

HTTPS / TLS

Encrypted web traffic. TLS is the protocol underneath.

Idle timeout

Automatic logout after a period without activity.

IKE

The protocol that negotiates IPsec keys and settings.

Implicit deny

Anything not allowed is dropped.

Inbound / destination NAT

Public destination rewritten to a private server.

Interface

A port on the firewall (X0, X1…), physical or virtual.

IP address

The number that identifies a device on a network, e.g. 192.168.168.100.

Lease

How long a client may keep its address.

Local backup

A snapshot kept on the appliance.

Local user

A user account stored on the firewall.

MAC address

The hardware address of a network card.

Management access

Which admin services (HTTPS, SSH, ping) a port answers.

MFA / TOTP

A second factor: a time-based one-time code.

Monitored interface

A link whose failure triggers failover.

Next hop

The router a packet is handed to.

NO_PROPOSAL_CHOSEN

No common encryption/PFS settings.

Packet capture

A record of packets and the firewall’s decision.

Password policy

Rules a password must meet: length and character types.

PFS

Perfect forward secrecy: fresh keys per tunnel.

ping (ICMP)

A reachability test: one echo request, one echo reply.

Port forwarding

Common name for publishing one port to an internal host.

Pre-shared key

A secret configured on both peers.

Profile

Which categories to block, plus exceptions.

Proposal

Encryption, hash and DH group offered.

Reservation

A fixed MAC → IP mapping inside DHCP.

Root cause analysis (RCA)

Cause, fix and prevention, written down.

Route

Destination network + next hop (gateway) + interface.

Rule hygiene

Regular review of order, usage and ownership.

Running configuration

What the firewall is doing right now.

Schedule

Days and hours when a rule is active.

Scope

Address range plus options served by DHCP on one interface.

SD-WAN

Policy-based selection between several WAN links.

Segmentation

Dividing a network so a breach stays contained.

Self-signed

A certificate signed by its own key. Encrypted, but unverified.

Serial number

Unique hardware identity of the unit.

Service group

A named set of services.

Service object

Protocol + port range.

Shadowed rule

A rule that can never match because an earlier one always does.

Signature / SID

A pattern of a known attack and its ID.

SLA probe

A regular test measuring reachability, latency and loss.

Source NAT

Rewriting the private source to a public address.

Split tunnel

Only listed networks go through the tunnel.

SSL VPN

Remote access tunnel over TLS.

Stateful sync

Copying the session table to the standby.

Sub-interface

A virtual interface for one VLAN on a physical port.

Subnet

The group of addresses that can talk directly. /24 means the first three numbers must match.

Subnet mask / CIDR

255.255.255.248 = /29 = 8 addresses.

Subscription service

A feature that needs an active licence and updates.

Syslog

Sending logs to a central server.

TLS inspection

Decrypting, inspecting and re-encrypting HTTPS.

Traffic selector

The local/remote networks a tunnel carries.

Trust store

The list of CAs a device trusts.

TS_UNACCEPTABLE

The networks do not match.

View

One of the six top-level areas.

VLAN

A logical network separated by a tag on the same cabling.

Zone

A trust label on interfaces. Rules are written between zones.

All traffic, hosts and attacks described here are simulated in the learner’s browser. ThreatWall is a fictional appliance used for training, and KGI is a fictional company. Completing the track earns internal badges that show progress inside this simulation; they are not a certification.

ThreatReady Firewall · Aerovant Technologies

© 2026 Aerovant Technologies · ThreatReady